Swiftradish Phase 3: Independent Red-Team Audit, Zero-Budget Architecture Verification, and Canonical Implementation Handoff

A. Executive Audit Verdict

1.1 Input Inventory and Audit Coverage

This Phase 3 independent red-team audit evaluates the complete project artifact chain against verified October 2026 vendor documentation, cloud infrastructure benchmarks, and primary Indian statutory notifications. In accordance with the project integrity gate, all prior assertions across the Phase 1 Blueprint and Phase 2 Specification are treated as unverified claims until corroborated by primary evidence.

Artifact / Input Source	Audit Status	Established Constraints ([USER DECISION] / [VERIFIED])	Challenged Blueprint & Phase 2 Claims	Critical Unverified Gaps Identified ([UNVERIFIED])
SWIFTRADISH_PHASE_3_GEMINI_RESEARCH_PROMPT.md & SWIFTRADISH_CONTEXT.md	Audited in Full	Clean-slate restart; solo builder operating with Cursor Pro (restricted to Grok and Composer 2.5); explicit user mandate to build using **free resources** ($0.00/month); existing Supabase project, Backblaze B2 bucket, and GitHub repository (Swiftradish) created.	Rejects any assumption that AI coding models make multi-subsystem real-time or security architectures cheap.	Exact cloud regions, bucket access policies, and account verification states for the provisioned Supabase and Backblaze B2 accounts remain uninspected ([UNVERIFIED]).
Swiftradish Product and Engineering Blueprint.pdf (Phase 1, 73	Audited in Full	Establishes the "Co-Plot" + "Radish Patch" co-active thesis, 40-screen catalog	**Contradicted:** Unilaterally replaces the user's Backblaze B2 bucket with	Retention targets (\ge 35\% D7, \ge 18\% D30) and Co-Action conversion (\ge

Artifact / Input Source	Audit Status	Established Constraints ([USER DECISION] / [VERIFIED])	Challenged Blueprint & Phase 2 Claims	Critical Unverified Gaps Identified ([UNVERIFIED])
pages)		(SCR-01 to SCR-40), "Nocturnal Botanical Studio" dark-first palette, 14-table UUIDv7 schema, and 216-pose "Pip the Radish" taxonomy.	Cloudflare R2, mandates a 40-screen MVP, and assumes a $49–69/month launch run-rate that violates the user's free-resource constraint.	28\% DAU) are unvalidated hypotheses presented as benchmarks ([UNVERIFIED]).
Swiftradish Phase 2 Specification Research.pdf (Phase 2 Reconciliation)	Audited in Full	Restores Backblaze B2 + Cloudflare Bandwidth Alliance CDN, pins Supabase ES256 JWKS verification, and trims the initial launch core to 22 screens across Slices 1–6.	**Partially Contradicted:** Still budgets $24–49/month for compute/Redis/Supabase Pro, misses the SQLAlchemy + asyncpg prepared_statement_cache_size bug on Supabase port 6543, and misses 2026 Indian IT Rules takedown timeline reductions.	Assumes synchronous pyvips image processing inside a low-memory web container will not trigger Out-of-Memory (OOM) crashes under burst uploads ([INFERENCE]).
Primary 2026 Vendor & Statutory Documentation	Verified via Primary Sources	Supabase Free Tier limits (500 MB DB, 50k MAU, 7-day pause); Backblaze B2 10 GB free tier + presigned PUT rules; Oracle Cloud Always Free June 2026 cut (2 OCPU / 12 GB Arm); Render April 2026 free tier cuts (5 GB bandwidth); Upstash Redis	Disproves Phase 1/2 hosting cost assumptions and exposes fatal prepared-statement and statutory SLA blind spots.	Legal applicability of DigiLocker age-token verification for adult-only platforms requires qualified Indian legal counsel ([UNVERIFIED]).

Artifact / Input Source	Audit Status	Established Constraints ([USER DECISION] / [VERIFIED])	Challenged Blueprint & Phase 2 Claims	Critical Unverified Gaps Identified ([UNVERIFIED])
		500k commands/mo free tier; India DPDP Rules 2025 & IT Amendment Rules 2026.		

1.2 Candid Executive Verdict and Implementation Readiness

Overall Implementation Readiness: CONDITIONALLY READY ([RECOMMENDATION], High Confidence).
The domain modeling, visual identity ("Nocturnal Botanical Studio"), and core product thesis of Swiftradish—turning static multi-image posts directly into collaborative "Co-Plots" (shared activity RSVPs, contextual group coordination threads, and multi-author photo carousels) anchored by topic "Patches"—represent a coherent, genuinely differentiated synthesis that bridges the gap between passive broadcast feeds (Instagram) and ephemeral scrollback chat (WhatsApp, Discord). However, both the Phase 1 Blueprint and the Phase 2 Specification fail the solo builder in three critical areas. First, both documents violate the explicit user mandate to build with **free resources**, proposing $24/month to $69/month infrastructure bills while ignoring how 2026 free-tier cloud constraints (Render's 15-minute sleep and 512 MB RAM ceiling, Koyeb's removal of card-free tiers, and Supabase's 7-day inactivity pause) interact with stateful WebSockets, arq workers, and pyvips image processing. Second, Phase 2's proposed SQLAlchemy + asyncpg configuration for Supabase's transaction pooler (port 6543) relies solely on statement_cache_size=0, which is proven by 2025–2026 production bug reports to crash under burst concurrency with DuplicatePreparedStatementError unless paired with NullPool, prepared_statement_cache_size=0, and randomized statement naming. Third, even Phase 2's trimmed 22-screen MVP remains too wide for a solo developer restricted to non-frontier coding models (Grok and Composer 2.5), and its moderation architecture relies on manual human review for 24-hour takedowns at a time when India's 2026 IT Rules amendments have compressed sensitive content takedown windows to **2 hours** (Rule 3(2)(b)) and general unlawful content to **36 hours**. Implementation may proceed only by adopting the **True $0.00/Month Zero-Budget Architecture**, the **15-Screen "Co-Plot First" Minimum Viable Launch Core**, and the **Zero-Touch Automated Statutory Quarantine Shield** established in this handoff.

1.3 Five Strongest Architectural & Product Decisions Retained

The audit confirms five foundational choices from the prior specifications that directly support long-term maintainability and product differentiation. First, Phase 2's decision to unify Co-Plot artifacts—merging Activity RSVPs, the contextual coordination thread, and the post-event Shared Memory Carousel into a single CO_PLOT post upgrade while eliminating Phase 1's separate "Visual Remix Strip" sub-mode—delivers the entire product promise inside one predictable UI card ([RECOMMENDATION], High Confidence). Second, preserving the builder's

existing Backblaze B2 bucket (allPrivate, 10 GB free storage, free Class A writes, 2,500 free Class B reads/day) behind a free Cloudflare Worker (cdn.swiftradish.app) with Cache-Control: public, max-age=31536000, immutable achieves $0.00 egress and $0.00 storage during MVP while preventing raw bucket enumeration ([USER DECISION] + [VERIFIED], High Confidence). Third, verifying Supabase JWTs locally in FastAPI via cached asymmetric JWKS (algorithms=["ES256"], pinned issuer and audience) eliminates the 40–120 ms network penalty of calling supabase.auth.get_user() on every request and blocks HS256/public-key algorithm confusion (CVE-2026-102266) ([VERIFIED], High Confidence). Fourth, using time-ordered 128-bit UUIDv7 keys across all 14 PostgreSQL tables eliminates B-Tree page fragmentation, prevents unread-message counter race conditions by comparing last_read_message_id against last_message_id, and enables deterministic cursor pagination (WHERE id < :cursor_id ORDER BY id DESC) ([VERIFIED], High Confidence). Fifth, explicitly separating browser presigned PUT completion from server HeadObject + 4 KB magic-byte inspection, EXIF GPS stripping, and atomic post linking—followed by wiping composer state and revoking blob URLs—prevents orphaned storage blobs and stuck composer inputs ([RECOMMENDATION], High Confidence).

1.4 Five Highest-Risk Weaknesses and Launch Blockers Identified

Conversely, the red-team review identified five severe architectural and operational flaws that would cause runtime outages, unexpected cloud bills, or statutory non-compliance if left uncorrected. The primary launch blocker is the false "low-cost" assumption versus true $0/month hosting reality ([VERIFIED], Critical Impact). Both Phase 1 and Phase 2 assume always-on FastAPI + arq + Redis containers costing 24–69/month; if the solo builder instead deploys to standard free PaaS tiers such as Render Free (512 MB RAM with 15-minute sleep and a 5 GB/month bandwidth limit since April 2026) or Railway's $1/month credit, stateful WebSockets will sever every 15 minutes, cold starts will stall requests for 60 seconds, and running Uvicorn + arq + pyvips in 512 MB RAM will trigger Linux OOM kills. A second launch blocker is the SQLAlchemy + asyncpg prepared statement crash on Supabase port 6543 ([VERIFIED], Critical Impact): Phase 2 specifies connect_args={"statement_cache_size": 0}, but SQLAlchemy 2.0's asyncpg dialect maintains a separate internal LRU cache (prepared_statement_cache_size) and assigns sequential names (__asyncpg_stmt_1__), causing fatal DuplicatePreparedStatementError exceptions under concurrent requests.
A third launch blocker involves India's 2026 IT Rules **2-hour takedown clock** versus solo human moderation ([VERIFIED], Critical Impact). Under the 2026 amendments to India's IT Rules 2021, takedown deadlines for sensitive complaints under Rule 3(2)(b) (privacy invasions, deepfakes, or impersonation) were cut from 24 hours to **2 hours**, and Rule 3(1)(b) timelines were cut from 72 hours to **36 hours**. Because a solo founder who is asleep cannot manually triage SCR-39 within 2 hours, the system must auto-quarantine reported CRITICAL items immediately on the first verified report (PENDING_MOD_SHIELD). Fourth, Supabase's Free Tier enforces a 7-day inactivity pause and a 500 MB database ceiling ([VERIFIED], High Impact), taking the entire application offline until manually restored in the dashboard unless mitigated by an automated keep-alive heartbeat and nightly database row pruning. Fifth, building 22 coupled screens, dual feeds, full-text + trigram search, custom reactions, nested comments, and real-time WebSocket chat simultaneously exceeds the reliable reasoning horizon of Grok and Composer 2.5 ([INFERENCE], High Impact), risking hallucinated imports and half-wired UI states unless the initial screen count is consolidated.

1.5 Scope Cuts and the Smallest Credible Release (MVP Core v1.0)

To guarantee that a solo builder using Grok and Composer 2.5 can ship a polished, bug-free product on $0.00/month infrastructure, the 22-screen Phase 2 launch list is consolidated into a **15-Screen Minimum Viable Co-Active Release (Slices 0–5)** ([RECOMMENDATION], High Confidence). Specifically, the initial release merges the standalone Discover feed screen (SCR-12) and Explore Directory (SCR-19 / SCR-20) into unified segmented views inside /home (SCR-11) and /explore (SCR-19 with inline search bar); folds the separate Multi-Image Crop/Alt-Text Drawer (SCR-16) directly into the Unified Composer modal (SCR-15) using client-side Canvas resize and EXIF stripping; merges Privacy/Blocks (SCR-34) and Account Deletion (SCR-37) into a single tabbed /settings surface (SCR-33); and replaces always-on Redis polling loops with a durable PostgreSQL outbox_jobs table. Meanwhile, the standalone 1:1 and Group DM Inbox (SCR-27 to SCR-30), Co-Plot .ics Calendar Hub (SCR-18), User-Created Patches (SCR-22—launching instead with 8 founder-seeded Patches), Bookmark Folders (SCR-26—retaining 1-tap flat bookmarks on the owner's profile in MVP), PWA Push Primer (SCR-10 / SCR-35), and Badge/Mascot Showcase (SCR-32) are deferred to Stage 2 post-beta validation.

B. Source and Factual Verification Ledger

Every high-impact technical, financial, platform, and legal claim from Phase 1 and Phase 2 has been audited against primary 2026 sources.

Claim Audited	Why It Matters	Original Source	Current Primary Verification (Oct 2026)	Verdict	Required Correction / Action	Confidence & Impact if Wrong
Supabase Free Tier provides 500 MB DB, 50,000 MAU Auth, 5 GB + 5 GB egress, and pauses after 7 days of inactivity ([VERIFIED]).	Determines whether the solo builder can launch at $0/mo without paying $25/mo for Supabase Pro on Day 1.	Phase 2 Sec 7.2 & 12.1	Official Supabase Pricing (2026): Free tier ($0/mo) includes 2 active projects, 500 MB Postgres DB, 50,000 MAUs, 1 GB file storage, 5 GB uncached + 5 GB cached egress, 200 concurrent Realtime connections, and pauses after 7 days	**Confirmed**	Retain Supabase Free Tier for MVP dev & closed beta ($0/mo$). $Addan$ 25/mo) only when DB reaches 400 MB.	**High** / High (App goes dark after 7 days idle if unmitigated).

Claim Audited	Why It Matters	Original Source	Current Primary Verification (Oct 2026)	Verdict	Required Correction / Action	Confidence & Impact if Wrong
			idle.			
SQLAlchemy + asyncpg works on Supabase Transaction Pooler (port 6543) simply by setting statement_cache_size=0 ([VERIFIED]).	Port 6543 uses Supavisor/PgBouncer in transaction mode, which does not support prepared statements across pooled connections.	Phase 2 Sec 7.2 & 15.2	Supabase GitHub Issues #36618, #39227 & SQLAlchemy/asyncpg docs (2025–2026): statement_cache_size=0 alone fails under burst load because SQLAlchemy's dialect caches statements via prepared_statement_cache_size and uses colliding sequential names (__asyncpg_stmt_1__).	**Contradicted**	Configure create_async_engine with poolclass=NullPool and connect_args={"statement_cache_size": 0, "prepared_statement_cache_size": 0, "prepared_statement_name_func": lambda: f"__asyncpg_{uuid4()}__"}.	**High** / Critical (Production 500 crashes on concurrent requests).
Backblaze B2 costs $0.006/GB/mo with 10 GB free, supports S3 presigned PUT (not POST), and gives $0 egress via Cloudflare ([VERIFIED]).	Governs media upload protocol and $0/mo storage viability.	Phase 2 REC-02, REC-03 & Sec 12.1	Backblaze B2 2026 S3 API & Pricing Docs: First 10 GB free forever; $6/TB/mo$ (0.006/GB) thereafter; Class A writes free; 2,500 Class B reads/day free; presigned	**Confirmed**	Mandate generate_presigned_url('put_object', ...) with signed Content-Type and Content-Length headers. Route public reads through a free Cloudflare Worker on	**High** / Critical (generate_presigned_post fails at runtime on B2).

Claim Audited	Why It Matters	Original Source	Current Primary Verification (Oct 2026)	Verdict	Required Correction / Action	Confidence & Impact if Wrong
			PUT (PutObject) supported, presigned POST unsupported; $0 egress via Cloudflare Bandwidth Alliance.		cdn.swiftradish.app with Cache-Control: public, max-age=31536000, immutable.	
Cloudflare R2 costs $0.015/GB/mo with 10 GB free, 1M Class A writes, 10M Class B reads, and $0 egress ([VERIFIED]).	Evaluates whether R2 is a viable zero-cost fallback if B2 US/EU upload latency from India is too high.	Phase 1 ADR-06; Phase 2 REC-02	Cloudflare R2 Pricing & Presigned URL Docs (Oct 2026): 10 GB-mo storage, 1M Class A writes/mo, and 10M Class B reads/mo are 100% free ($0/mo); presigned PUT works on .r2.cloudflarestorage.com (not custom domains) and requires bucket CORS.	**Confirmed**	Keep Backblaze B2 as primary ([USER DECISION]), but abstract storage behind S3StorageService so switching to Cloudflare R2's 10 GB free tier (which has APAC edge placement) requires changing only 4 environment variables.	**High** / Medium (Sub-optimal upload latency if B2 US-West is slow from India).
FastAPI + WebSockets + arq + Redis requires $24–69/mo paid hosting on Railway, Fly.io, or	Directly conflicts with the user's explicit instruction to build with **free resources** ($0/mo).	Phase 1 Doc G ($49–69/mo); Phase 2 Sec 12.2 ($24–49/mo)	2026 Free Hosting Audit: Railway free plan gives only $1/mo credit; Koyeb removed card-free	**Outdated / Contradicted**	Provide a **True $0.00/Month Zero-Budget Stack**: (Option A) Oracle Cloud Always Free 2-OCPU / 12	**High** / Critical (Paid bills or OOM crashes on 512 MB containers).

Claim Audited	Why It Matters	Original Source	Current Primary Verification (Oct 2026)	Verdict	Required Correction / Action	Confidence & Impact if Wrong
Render ([VERIFIED]).			Hobby in Feb 2026; Render cut free bandwidth to 5 GB/mo in Apr 2026 and sleeps after 15m idle (512 MB RAM). However, **Oracle Cloud Always Free** provides 2 Arm OCPUs + 12 GB RAM 24/7 ($0/mo, cut from 4 OCPU/24 GB on June 15, 2026), and **Upstash Redis** provides 250 MB + 500k commands/mo free ($0/mo).		GB RAM Arm VM running FastAPI + Redis + arq 24/7; or (Option B) Render/HF Spaces Free + Upstash Free Redis (500k cmds/mo) with event-driven WebSockets and client-assisted WebP compression.	
Supabase Auth JWTs use asymmetric ES256 JWKS and allow public-key forgery if HS256 is permitted ([VERIFIED])	Prevents total authentication bypass (CVE-2026-102266) and SSRF.	Phase 2 REC-05 & Sec 10.1	Supabase Signing Keys Docs (2025–2026): Exposes asymmetric ES256 keys at /auth/v1/.well-known/jwks.json; mixing HS256 and	**Confirmed**	Hardcode SUPABASE_JWKS_URL and EXPECTED_ISSUER in backend config; restrict jwt.decode() strictly to algorithms=["	**High** / Critical (Complete auth forgeability if misconfigured).

Claim Audited	Why It Matters	Original Source	Current Primary Verification (Oct 2026)	Verdict	Required Correction / Action	Confidence & Impact if Wrong
.			ES256 or reading iss before verification enables forgery/SSRF.		ES256"] and audience="authenticated".	
India DPDP Act 2023 & DPDP Rules 2025 were notified Nov 13–14, 2025 with 72h breach notice and May 2027 full enforcement ([VERIFIED]).	Governs registration consent UI, 18+ age gate, and data breach runbooks.	Phase 2 REC-06 & Sec 10.2	MeitY Notification G.S.R. 843(E)/844(E)/846(E) (Nov 13–14, 2025): DPB established immediately; Consent Managers Nov 14, 2026; full compliance May 13–14, 2027; Rule 7 mandates 72h breach reporting with zero materiality threshold; Section 9 requires verifiable parental consent for <18.	**Confirmed**	Enforce 18+ age gate at /register, standalone itemized consent checkbox, and 72-hour breach reporting tool in SCR-39. Flag DigiLocker age verification for Indian counsel.	**High** / High (Statutory penalties up to ₹200–250 crore after enforcement).
India IT Rules 2021 allow 24 hours for Rule 3(2)(b) sensitive takedowns and 72 hours	Determines whether manual moderation by a solo founder is legally safe in India.	Phase 1 SR-04; Phase 2 REC-07 & Sec 10.2	MeitY IT (Intermediary Guidelines) Amendment Rules, 2026: Cut Rule 3(2)(b) sensitive	**Outdated**	Update CRITICAL_24H SLA tier to **CRITICAL_2H** (sla_deadline_at = NOW()	**High** / Critical (Loss of safe-harbor protection under Sec 79 IT Act if a 2-hour

Claim Audited	Why It Matters	Original Source	Current Primary Verification (Oct 2026)	Verdict	Required Correction / Action	Confidence & Impact if Wrong
for Rule 3(1)(b) user reports ([VERIFIED]).			privacy / impersonation / deepfake takedown deadlines from **24 hours to 2 hours** (and 72-hour timelines to **36 hours**), while retaining 180-day preservation under Rule 3(1)(g).		+ INTERVAL '2 hours') and STANDARD_72H to **STANDARD_36H**. Implement **instant automated quarantine (PENDING_MOD_SHIELD)** on the first CRITICAL_2H report so public access is disabled in <1s without waiting for the solo founder to wake up.	deadline is missed overnight).
Competitor & Retention Claims: 28% DAU Co-Action conversion, 35% D7 retention, and sub-100ms API latency ([UNVERIFIED]).	Prevents mistaking aspirational product goals for empirically proven baselines.	Phase 1 Doc A & Doc G	No empirical user data exists for Swiftradish; latency and retention figures in Phase 1 are architectural design targets and product hypotheses, not measured benchmarks.	**Unverifiable (Target Only)**	Reclassify all retention, conversion, and latency numbers strictly as **Target SLOs and Validation Hypotheses**.	**High** / Medium (Over-building Stage 2 features before validating core loop).

C. Product Thesis and Market Red Team

3.1 Critical Challenge of the Product Thesis and Core Loop

A rigorous red-team evaluation of the "co-active social platform" thesis reveals both a genuine

market wedge and a severe risk of feature bloat. Incumbent platforms suffer from a real structural split: visual discovery happens on algorithmic broadcast networks (Instagram, Pinterest) where friend coordination is relegated to forwarded DMs, while actual group planning happens in ephemeral chat threads (WhatsApp, Discord) where time slots, RSVP headcounts, and post-event photos rapidly vanish in scrollback. However, a critical question must be answered honestly: *Does a Co-Plot create a measurably better outcome than an Instagram post plus a WhatsApp group and a shared Google Photos album?*

The audit concludes that a Co-Plot beats the incumbent workaround **only** when it collapses three high-friction handoffs into a single persistent URL (/p/[postId]): (1) visual invitation and 1-tap headcount (Going / Maybe with atomic capacity locking), (2) a scoped coordination thread directly attached to that post, and (3) a **Shared Memory Carousel** where participants upload their own photos during or after the meetup and receive direct @handle attribution on their contributed slides. In WhatsApp or Discord, post-event photo collection fails because participants forget to upload to external Drive links, and photos dumped into chat lose curation and public portfolio value. In Instagram, collaborative posts are capped at a small number of co-authors invited before or at publication time and lack an integrated event RSVP roster or attendee thread.

Conversely, Phase 1's attempt to simultaneously build a Discord competitor (Patches with up to 3 real-time chat channels), a Twitter/Reddit quote-remix network ("Visual Remix Strips"), a 216-pose Duolingo-style mascot/badge engine ("Pip the Radish"), and a standalone full-featured DM inbox dilutes the core loop and overwhelms the user with unfamiliar botanical jargon. If a new user lands on a screen presenting "My Patch," "Fresh Harvest," "Radish Patches," "Co-Plots," "Sprouts," and "Pip" simultaneously, cognitive friction will cause immediate drop-off ([INFERENCE], High Confidence). Therefore, every botanical brand term in the UI must be subordinated to standard functional labels: **Following (My Patch)**, **Discover (Fresh Harvest)**, **Communities (Patches)**, and **Shared Activities & Albums (Co-Plots)**.

3.2 Feature-by-Feature Red-Team Decision Matrix and Effort Audit

Evaluating actual implementation, testing, security, and operational maintenance effort for a solo builder using Cursor Pro (Grok / Composer 2.5) dictates a decisive pruning of the MVP surface area.

Feature ID & Subsystem	Phase 1 / Phase 2 Status	Phase 3 Final Audit Verdict	Solo-Builder Effort & Hidden Operational Burden	Hard-to-Reverse Commitments & Trade-Offs	Trigger Evidence Required to Unlock / Expand
F-01: 18+ Auth, Supabase ES256 JWKS & Profiles	MVP Core (Slice 1)	**Keep in MVP Core (Slice 1)** ([RECOMMENDATION])	**Effort:** Low-Medium (3–4 days). **Hidden Burden:** Handling cookie synchronization between Next.js SSR	Binding users.id 1:1 to Supabase auth.users.id (UUID). Easy to migrate later via standard pg_dump.	Mandatory foundation for all authenticated actions and DPDP Section 9 age gating.

Feature ID & Subsystem	Phase 1 / Phase 2 Status	Phase 3 Final Audit Verdict	Solo-Builder Effort & Hidden Operational Burden	Hard-to-Reverse Commitments & Trade-Offs	Trigger Evidence Required to Unlock / Expand
			and FastAPI, plus rate-limiting OTP abuse.		
F-02: Hybrid Social Graph (Follow + Auto-Mutual + Private Accounts)	MVP Core (Slice 2)	**Keep in MVP Core (Slice 2)** ([RECOMMENDATION])	**Effort:** Medium (4 days). **Hidden Burden:** Every SQL query across feeds, search, and profiles must enforce is_private and user_blocks checks (Plane 2 BOLA).	Relational user_relationships trigger computing is_mutual = TRUE. Essential for frictionless mutual Co-Plot uploads.	Mandatory before enabling collaborative carousel contributions.
F-03: Block, Mute, Report & Zero-Touch Statutory Quarantine	MVP Core (Slice 6)	**Keep in MVP Core — Upgrade to Zero-Touch Shield (Slice 5)** ([VERIFIED])	**Effort:** Medium (4 days). **Hidden Burden:** India's 2026 IT Rules amendments mandate a **2-hour** takedown for sensitive Rule 3(2)(b) complaints. Manual solo-founder review cannot meet 2h 24/7.	Requires moderation_status = 'PENDING_MOD_SHIELD' to auto-hide CRITICAL_2H reported items in <1s pending human review.	Legally non-negotiable for public launch in India.
F-04: Multi-Image Carousel Composer (Direct-to-B2 PUT + EXIF Strip)	MVP Core (Slice 3)	**Keep but Simplify Architecture (Slice 3)** ([RECOMMENDATION])	**Effort:** High (5–6 days). **Hidden Burden:** Server-side pyvips decoding of 10 concurrent 15 MB images will	Fold SCR-16 crop/alt-text into SCR-15. Perform primary WebP resize (\le 20[span_38](start_span)[span_38](end_span)	Core creative primitive; required for all visual posts and Co-Plots.

Feature ID & Subsystem	Phase 1 / Phase 2 Status	Phase 3 Final Audit Verdict	Solo-Builder Effort & Hidden Operational Burden	Hard-to-Reverse Commitments & Trade-Offs	Trigger Evidence Required to Unlock / Expand
			OOM a 512 MB free-tier container.	48\text{px}) and EXIF strip in browser WebWorker first, followed by strict server pyvips verification with asyncio.Semaphore(2).	
F-05: Collaborative "Co-Plot" Cards (RSVP + Shared Carousel + Plot Thread)	MVP Core (Slice 4)	**Keep in MVP Core (Slice 4)** ([RECOMMENDATION])	**Effort:** High (6–7 days). **Hidden Burden:** Race conditions on RSVP capacity limits and host approval queues for non-mutual photo submissions.	Unifies posts, co_plots, co_plot_participants, and conversations (CO_PLOT_THREAD). Drop "Visual Remix Strip" sub-mode.	Primary product differentiator; must be tested in closed beta first.
F-06 & F-09: Dual Feeds (My Patch / Fresh Harvest), Starter Patches & Search	MVP Core (Slice 5)	**Keep but Consolidate Screens (Slice 5)** ([RECOMMENDATION])	**Effort:** Medium (5 days). **Hidden Burden:** Cold-start empty feeds kill retention; GIN tsvector + pg_trgm indexes consume precious MBs on Supabase's 500 MB free tier.	Merge SCR-11/SCR-12 into one /home route and SCR-19/SCR-20 into one /explore route. Pre-seed 8 founder Patches; defer user Patch creation (SCR-22) to Stage 2.	Unlock user-created Patches (SCR-22) only when >15 active Co-Plots/week occur across starter Patches.
F-07: Reactions, 3-Level Comments, Bookmarks &	MVP Core Simplified (Slice 5)	**Keep Reactions, Comments & Flat Bookmarks;**	**Effort:** Medium (3–4 days). **Hidden Burden:** Recursive	Cap comment depth BETWEEN 0 AND 2 with tombstone	Revisit Quote-Remixes only if >20\% of comments reference

Feature ID & Subsystem	Phase 1 / Phase 2 Status	Phase 3 Final Audit Verdict	Solo-Builder Effort & Hidden Operational Burden	Hard-to-Reverse Commitments & Trade-Offs	Trigger Evidence Required to Unlock / Expand
Quote-Remixes		**Remove Quote-Remixes** ([RECOMMENDATION])	comment trees and quote-remix chains create complex moderation and deletion cascades.	soft-deletion. Defer Bookmark Folders (SCR-26) to Stage 2 and remove Quote-Remixes.	starting a follow-up activity.
F-08: Real-Time WebSockets (Co-Plot Thread vs. 1:1/Group DM Inbox)	Staged (Plot Thread Slice 4; DM Inbox Slice 7)	**Keep Plot Thread in MVP (Slice 4); Defer 1:1/Group DM Inbox to Stage 2** ([RECOMMENDATION])	**Effort:** Very High for full DM inbox (8–10 days). **Hidden Burden:** Unsolicited DM spam, Message Requests quarantine (SCR-29), read-receipt privacy, and Upstash Redis command burn.	Ship CO_PLOT_THREAD inside SCR-13 using the durable conversations & messages tables with WebSocket + REST fallback. Defer SCR-27 to SCR-30 to Stage 2.	Unlock standalone 1:1 DM Inbox (SCR-27–30) only after Co-Plot conversion exceeds 20\% WAU in beta.
F-10: In-App Activity Center & PWA Web Push	In-App Slice 6; Push Slice 8	**Keep In-App Activity Center (Slice 5); Defer Web Push to Stage 2** ([RECOMMENDATION])	**Effort:** Low for In-App (2 days); Medium-High for iOS Web Push (3–4 days) due to standalone Home Screen installation requirements.	Deduplicated notifications table (ON CONFLICT (recipient_id, dedupe_key) DO UPDATE) ships in MVP. VAPID Web Push (SCR-10, SCR-35) moves to Stage 2.	Unlock Web Push once D7 beta retention reaches \ge 25\%.
F-11 & F-14: "Pip the Radish" Mascot (8 / 30 / 216 Poses) &	8 Static SVGs in MVP; 30/216 in Stage 2	**Simplify to 6 Static SVGs in MVP; Defer Badges & 30/216 Poses**	**Effort:** Low for 6 SVGs (1 day); High for anti-farming badge triggers	Ship 6 static layered SVGs (<8 KB each) for Empty, 404, Offline,	Expand mascot library only after D30 cohort retention \ge 18\%.

Feature ID & Subsystem	Phase 1 / Phase 2 Status	Phase 3 Final Audit Verdict	Solo-Builder Effort & Hidden Operational Burden	Hard-to-Reverse Commitments & Trade-Offs	Trigger Evidence Required to Unlock / Expand
Badges		([RECOMMENDATION])	and 216-pose vector rig.	Onboarding, Upload, and Safety states. Defer SCR-32 badge engine.	
F-12, F-13, F-15, F-16: Video (60s), 24h "Sprouts", Payments & E2EE	Deferred / Rejected	**Defer Video/Sprouts; Reject Payments, Calls & E2EE** ([RECOMMENDATION])	**Effort:** Extreme. Video requires paid Cloudflare Stream ($5/1k mins); payments require KYC/GST; E2EE breaks search and statutory IT Rules moderation.	Zero video transcoding or payment tables in MVP schema.	Measure clicks on a lightweight "Video (Coming Soon)" tooltip in closed beta before provisioning Cloudflare Stream.

3.3 Low-Cost Pre-Scale Validation Experiments

Before writing a single line of Stage 2 code, the solo builder must execute three zero-cost validation experiments with an initial cohort of 50–100 target users, such as local university photography, urban sketching, or run clubs in Hyderabad ([RECOMMENDATION], High Confidence). In the first experiment (the **Concierge Co-Plot Link Test** during Week 1 post-MVP), five club organizers create a real weekend meetup Co-Plot on Swiftradish and paste the canonical /p/[postId] link into their existing WhatsApp groups; the hypothesis passes if at least 50\% of attendees RSVP via the Swiftradish deep link rather than replying in WhatsApp, and at least 20\% of weekly active users either RSVP or contribute a carousel slide within 14 days. In the second experiment (the **Multi-Author Shared Memory Carousel Test** during Weeks 2–3), the builder tracks post-event uploads in the 24 hours following each scheduled Co-Plot activity; at least 25\% of hosted Co-Plots must receive approved photo slide contributions from two or more distinct participants (contributor_id <> author_id). If users RSVP on Swiftradish but revert to dumping photos in WhatsApp afterward, the upload UX in SCR-13 must be simplified before building any Stage 2 features. In the third experiment (**Fake-Door Demand Telemetry**), lightweight, honest telemetry pills for deferred concepts (such as "Export .ics Calendar" or "Video clip (Coming in Beta 2)") are instrumented so Stage 2 engineering only proceeds for features registering at least 10\% unique user interaction intent.

D. Screen, State, and Accessibility Audit

4.1 Audit of the 40-Screen Catalog and Consolidation into the

15-Screen MVP Core

Auditing Phase 2's 22-screen MVP catalog reveals seven fragmented sub-views and duplicate routes that artificially inflate navigation complexity and coding-agent prompt overhead. By consolidating sub-drawers and tab views into their parent route containers while preserving the canonical SCR-* identifiers for architectural traceability, the initial launch surface is reduced to **15 cohesive screens/modals** across 4 route groups: (public), (auth), (main), and (legal) ([RECOMMENDATION], High Confidence).
The table below documents the complete screen, state, API dependency, and accessibility audit across all 15 retained MVP Core surfaces (incorporating the 7 consolidated sub-views).

Screen ID & Canonical Route	Phase 3 Disposition & Slice	Primary User Task & Durable Outcome	Covered vs. Missing UI States Fixed in Audit	Required API & Database Dependencies	WCAG 2.2 AA & Interaction Audit Corrections	Severity & Gate Status
SCR-01: Public Landing & Manifesto (/)	**Keep in MVP Core** (Slice 0/1)	Understand co-active thesis; preview real public Co-Plots; route to /register or /login.	**Fixed:** Added fallback to static curated showcase card if backend SSR fetch exceeds 1500ms (e.g., during cold wake-up).	GET /api/v1/public/showcas[span_157](start_span)[span_157](end_span)e (60s edge cache); 307 redirect to /home if session cookie valid.	Landmarks <header>, <main>, <footer>; zero fabricated user counters; interactive demo Co-Plot toggle uses aria-pressed.	**Medium** — Mandatory Slice 1 Gate
SCR-02 & SCR-13: Unified Post & Co-Plot Detail View (/p/[postId])	**Consolidate SCR-02 + SCR-13** (Slice 4)	Read shared post/Co-Plot via deep link (anon SSR or auth), swipe carousel, RSVP (Going/Maybe), upload slide, and chat in Plot Thread.	**Fixed:** Phase 2 split anon (SCR-02) and auth (SCR-13) into separate specs. Audit unifies them into one route component that renders an auth-trigger banner for anon callers and optimistic	GET /api/v1/posts/{id}, GET/POST /api/v1/posts/{id}/comments, POST /api/v1/plots/{id}/rsvp, POST /api/v1/plots/{id}/submissions, WS /ws.	Serves absolute og:image URL for WhatsApp/Instagram unfurling; arrow-key carousel navigation; RSVP buttons announce capacity (9 of 12 Going) via aria-live="polite".	**Critical** — Core Loop Surface

Screen ID & Canonical Route	Phase 3 Disposition & Slice	Primary User Task & Durable Outcome	Covered vs. Missing UI States Fixed in Audit	Required API & Database Dependencies	WCAG 2.2 AA & Interaction Audit Corrections	Severity & Gate Status
			RSVP/chat controls for authenticated users, plus 409 ERR_PLOT_FULL rollback state.			
SCR-03 & SCR-21: Radish Patch Community Space (/patches/[slug])	**Consolidate SCR-03 + SCR-21** (Slice 5)	Browse topic community feed and upcoming Co-Plots (anon read-only preview or authenticated member participation).	**Fixed:** Unifies public preview (SCR-03) and member view (SCR-21) into one route. Blocks unauthenticated scraping of member lists; adds 403 ERR_NOT_PATCH_MEMBER guard if non-member attempts to post.	GET /api/v1/patches/{slug}, POST /api/v1/patches/{slug}/join, GET /api/v1/patches/{slug}/posts.	Tabs (Curated Feed, Upcoming Co-Plots) use role="tablist" and role="tab" with roving tabindex.	**High** — Cold-Start Anchor
SCR-04: 18+ Sign-Up & DPDP Consent (/register)	**Keep in MVP Core** (Slice 1)	Create 18+ account with explicit, unbundled DPDP 2025 consent notice.	**Fixed:** Added 250ms response timing floor on existing-email collisions so attackers cannot enumerate accounts, plus	POST /api/v1/auth/register + Supabase Auth OTP dispatch.	Keyboard-accessible native/segmented DOB inputs (no mouse-only calendar trap); aria-invalid and aria-describedby wired to field errors.	**Critical** — Legal & Security Gate

Screen ID & Canonical Route	Phase 3 Disposition & Slice	Primary User Task & Durable Outcome	Covered vs. Missing UI States Fixed in Audit	Required API & Database Dependencies	WCAG 2.2 AA & Interaction Audit Corrections	Severity & Gate Status
			non-retriable AGE_REJECTED screen (HTTP 422) storing zero PII.			
SCR-05 & SCR-06: Login & Password Recovery (/login, /auth/reset-password)	**Consolidate Auth Flows** (Slice 1)	Authenticate returning user, restore ?next= deep link, or reset password with full session revocation.	**Fixed:** Enforces strict regex validation on next query parameter (^\/[a-zA-Z0-9_\-\/\?=&]*$, rejecting // or http) to block open redirects.	Supabase Auth signInWithPassword, POST /api/v1/auth/revoke-all.	Focus shifts automatically to role="alert" banner on 401/429 failure; live countdown timer on 429 rate limit.	**High** — Auth Boundary
SCR-07: Email OTP Verification (/auth/verify)	**Keep in MVP Core** (Slice 1)	Confirm email via 6-digit OTP code.	**Fixed:** Added 15-minute lockout state after 5 failed OTP guesses and 60s resend cooldown timer.	POST /api/v1/auth/verify-otp (inserts durable users + user_profiles rows on success).	6 inputs wrapped in <fieldset> with <legend>; full 6-digit clipboard paste auto-fills all boxes and triggers validation.	**High** — Identity Gate
SCR-08 & SCR-09: Two-Step Onboarding Wizard (/onboarding)	**Consolidate SCR-08 + SCR-09** (Slice 1 & 5)	Step 1: Claim @username and profile identity. Step 2: Join \ge 3 pre-seeded starter Patches.	**Fixed:** Prevents partial onboarding state drift by gating /home behind onboarding_step == 3 and providing 3 clickable	GET /api/v1/users/check-username, PATCH /api/v1/users/me, POST /api/v1/onboarding/complete.	Debounced (300ms) handle check announces availability via aria-live="polite"; Patch cards use role="checkbox" with Space/Enter	**High** — Cold-Start Gate

Screen ID & Canonical Route	Phase 3 Disposition & Slice	Primary User Task & Durable Outcome	Covered vs. Missing UI States Fixed in Audit	Required API & Database Dependencies	WCAG 2.2 AA & Interaction Audit Corrections	Severity & Gate Status
			handle suggestions on 409 username collision.		toggle.	
SCR-11 & SCR-12: Dual-Mode Home Feed (/home)	**Consolidate into Single Route** (Slice 5)	Switch seamlessly between **Following (My Patch)** chronological feed and **Discover (Fresh Harvest)** explainable ranked feed.	**Fixed:** Eliminates duplicate route code by rendering both modes via `?tab=following	discover. Adds "You're all caught up"divider atlast_seen_post_id` and cached offline read banner.	GET /api/v1/feed/following?cursor=..., GET /api/v1/feed/discover?cursor=..., POST /api/v1/safety/mutes.	Every Discover card includes a keyboard-accessible provenance button (Why this post?) and 1-tap Mute Author/Topic control; J/K keyboard navigation.
SCR-14: Media Lightbox & Carousel Inspector (?media=[idx])	**Keep in MVP Core** (Slice 3)	Inspect 2048w full-resolution WebP slides, contributor credits (@handle), and full alt-text.	**Fixed:** Added broken-image retry fallback and strict scroll-lock cleanup on unmount so background feed never freezes.	Hydrated from parent post.media_assets array.	Radix Dialog focus trap; Escape closes and invokes router.back() restoring exact feed scroll offset; Left/Right arrow keys switch slides.	**Medium** — Media Polish Gate
SCR-15 & SCR-16: Unified Post & Co-Plot Composer + Inline Crop/Alt-Text (/compose)	**Consolidate SCR-15 + SCR-16** (Slice 3 & 4)	Attach 1–10 images, crop/reorder/add alt-text inline, optionally toggle Make Co-Plot, and publish with idempotency.	**Fixed:** Merges SCR-16 inside SCR-15. Enforces all 8 deterministic upload states (EMPTY	POST /api/v1/media/upload-intents, presigned PUT to B2, POST /api/v1/media/{id}/complete, POST /api/v1/posts	Explicit Move Left / Move Right buttons alongside drag-and-drop for non-pointer keyboard users; progress	**Critical** — Highest Technical Risk

Screen ID & Canonical Route	Phase 3 Disposition & Slice	Primary User Task & Durable Outcome	Covered vs. Missing UI States Fixed in Audit	Required API & Database Dependencies	WCAG 2.2 AA & Interaction Audit Corrections	Severity & Gate Status
			\rightarrow POST_COMMITTED) plus POST_SUBMIT_ERROR (retaining READY media_ids in IndexedDB so retry publishes without re-uploading bytes).	(Idempotency-Key required).	rings expose role="progressbar" and aria-valuenow.	
SCR-17: Co-Plot Contribution Approval Queue (/p/[postId]/manage)	**Keep in MVP Core** (Slice 4)	Allow Co-Plot host to approve or decline pending carousel photo submissions from participants.	**Fixed:** Added cap check (25 max collaborative slides per Co-Plot) and 5-second undo toast on Decline before scheduling B2 object deletion.	GET /api/v1/plots/{id}/submissions, POST /api/v1/plots/{id}/submissions/{subId}/decide (restricted to post.author_id, returns 404 to others).	Action buttons explicitly labeled (Approve slide from @user, Decline slide from @user); status changes announced to screen readers.	**High** — Co-Plot Trust Gate
SCR-19 & SCR-20: Explore & Unified Search Hub (/explore)	**Consolidate SCR-19 + SCR-20** (Slice 5)	Browse starter Patches & weekend Co-Plots, or execute instant tsvector + pg_trgm hybrid search across @users, Patches, and	**Fixed:** Combines Explore directory and Search results into a single /explore?q=...&type=... surface with 250ms debounce and	GET /api/v1/explore/hub, GET /api/v1/search?q=...&type=...&cursor=...	Combobox pattern (role="combobox", aria-activedescendant) for typeahead; spelling suggestions (Did you mean...?) via pg_trgm similarity.	**High** — Discovery Gate

Screen ID & Canonical Route	Phase 3 Disposition & Slice	Primary User Task & Durable Outcome	Covered vs. Missing UI States Fixed in Audit	Required API & Database Dependencies	WCAG 2.2 AA & Interaction Audit Corrections	Severity & Gate Status
		Co-Plots.	AbortController cancellation of stale in-flight requests.			
SCR-23, SCR-24 & SCR-25: User Profile, Editor & Relationships (/u/[username])	**Consolidate Profile Suite** (Slice 2)	View user's Posts, Co-Plots, and Bookmarks (owner-only tab); edit profile/theme modal (SCR-24); manage Followers, Following, Mutuals & Requests modal (SCR-25).	**Fixed:** Consolidates flat Bookmarks (SCR-26) as an owner-only private tab on /u/[username] for MVP, and turns SCR-24/SCR-25 into accessible slide-over drawers on the profile route.	GET /api/v1/users/{username}/profile, PATCH /api/v1/users/me/profile, GET /api/v1/users/{id}/relations, POST /api/v1/relations/requests/{id}/decide.	Private accounts enforce SQL-level filtering (non-followers receive header summary only); theme swatches include text labels and guarantee \ge 4.5:1 contrast.	**High** — Social Graph Gate
SCR-31: Activity Center Notifications Hub (/notifications)	**Keep in MVP Core** (Slice 5)	Review deduplicated updates on Co-Plots, RSVPs, slide approvals, follows, and replies.	**Fixed:** High-frequency reactions and joins roll up into a single row (@alice and 4 others joined your Co-Plot) via dedupe_key.	GET /api/v1/notifications?filter=..., POST /api/v1/notifications/mark-read.	Unread state communicated via visually hidden Unread: text prefix in addition to the #FF4D5E crimson dot.	**High** — Return Loop Gate
SCR-33, SCR-34, SCR-36, SCR-37, SCR-38, SCR-39 &	**Consolidate Safety & Settings Suite** (Slice 1 & 5)	Manage sessions, privacy, blocked/muted users, data export, and	**Fixed:** Updated SCR-36 and SCR-39 to enforce India's 2026	POST /api/v1/safety/reports, GET /api/v1/safety/my-reports, POST	Destructive confirmation modals focus Cancel by default; SCR-40	**Critical** — Statutory Compliance Gate

Screen ID & Canonical Route	Phase 3 Disposition & Slice	Primary User Task & Durable Outcome	Covered vs. Missing UI States Fixed in Audit	Required API & Database Dependencies	WCAG 2.2 AA & Interaction Audit Corrections	Severity & Gate Status
SCR-40: Unified Settings, Statutory Safety, Admin Triage & Error Suite (/settings, /internal/moderation, /legal/grievance)		14-day account deletion (/settings); file statutory reports (SCR-36), track/appeal tickets (SCR-38), and triage SLA queues (SCR-39).	IT Rules **2-hour (CRITICAL_2H)** and **36-hour (STANDARD_36H)** clocks with instant automated quarantine (PENDING_MOD_SHIELD) on CRITICAL_2H reports.	/api/v1/admin/moderation/cases/{id}/resolve, POST /api/v1/account/schedule-deletion.	(error.tsx, not-found.tsx, /offline) focuses <h1> on mount and announces Retry-After countdowns.	

4.2 Concrete Definition of Done (DoD) for Every MVP Screen

No screen in Slices 1–5 may be marked complete by the coding agent unless it satisfies seven strict verification criteria ([RECOMMENDATION], High Confidence). First, the component tree must contain zero mock imports or static fixture arrays, with all data flowing from typed FastAPI /api/v1/* endpoints persisted in PostgreSQL 16. Second, the complete state matrix—including Loading (aspect-ratio-locked skeletons), Empty (honest copy + Pip static SVG), Populated, Validation Error, Network/500 Error with inline Retry, Rate-Limited (429 countdown), and Destructive Confirmation states—must be implemented and reachable. Third, toast confirmations (Post planted!, Slide approved, Report submitted) must fire strictly after the server returns HTTP 200/201/202 or WebSocket msg.ack. Fourth, after completing any mutation (publishing a post in SCR-15, sending a message in SCR-13, or filing a report in SCR-36), the interface must execute a clean state reset so the user can immediately perform a second action without refreshing the browser tab or encountering stale blob URLs or disabled buttons. Fifth, every underlying endpoint must enforce Plane 1 (RBAC) and Plane 2 (Ownership, Visibility, and Bidirectional user_blocks check) in SQL, returning 404 Not Found to unauthorized callers. Sixth, the screen must pass @axe-core/playwright with zero WCAG 2.2 AA violations at 1440x900 (Desktop) and 390x844 (Mobile), full keyboard tab/arrow navigation, and prefers-reduced-motion: reduce compliance. Finally, unit, integration (pytest), and browser E2E (playwright) tests must have actually executed in the terminal and exited 0.

E. Canonical Interaction Flows and State-Machine Audit

5.1 Contradictions Resolved Across Prior Specifications

Auditing the interaction flows across Phase 1 and Phase 2 uncovered three state-machine contradictions that must be corrected before implementation ([VERIFIED], High Confidence).
The first contradiction involves synchronous versus asynchronous media processing in State 5 (VERIFYING_PROCESSING): Phase 1 Document D specified that POST /api/v1/media/{id}/complete could enqueue an arq job while setting status to READY, whereas Phase 2 Section 8.2 mandated synchronous pyvips variant generation inside complete with fallback to 202 Accepted (VERIFYING) if the thread pool is saturated, yet omitted a client polling loop in SCR-15 when 202 Accepted is returned. To prevent server RAM exhaustion on free-tier compute (512 MB to 12 GB RAM) while keeping complete under 400ms, the browser WebWorker (SCR-15 State 2) performs initial resizing (\le 2048\text{px} max dimension) and client-side EXIF stripping prior to presigned PUT upload. On POST /api/v1/media/{id}/complete, FastAPI acquires an in-memory asyncio.Semaphore(2), verifies the first 4 KB magic bytes and header dimensions (<= 8192x8192), strips any remaining metadata via streaming pyvips, writes the WebP delivery variants to media/{media_id}/, deletes the staging/ object, and returns 200 OK (status = 'READY'). If the semaphore cannot be acquired within 2.0s, complete returns 202 Accepted (status = 'VERIFYING') and the client automatically polls GET /api/v1/media/{id}/status at 1500ms intervals (max 10 polls) before transitioning to MEDIA_READY.
The second contradiction involves Co-Plot capacity checks versus optimistic RSVP UI. Phase 2 specified optimistic UI toggling on Going RSVPs alongside a server-side SELECT ... FOR UPDATE capacity lock; however, if two users claim the final spot in a 12-person Co-Plot simultaneously, the loser receives 409 ERR_PLOT_FULL, leaving their optimistic Going pill out of sync with the chat roster. To resolve this, the client sets a transient RSVP_SAVING state on click, commits Going green (#2EE59D) and mounts the Plot Thread composer strictly upon receiving 200 OK with conversation_id, and rolls back to the prior state with an alert toast if 409 ERR_PLOT_FULL is returned.
The third contradiction involves moderation quarantine delays versus India's 2-hour statutory clock. Both prior reports routed CRITICAL user reports into an admin queue (SCR-39) and required two or more distinct reports before auto-shielding. Under India's 2026 IT Rules amendments (2-hour takedown for Rule 3(2)(b) privacy violations, impersonation, or deepfakes), waiting for a second report or manual review while the solo founder sleeps violates the 2-hour statutory ceiling. Consequently, any single report submitted under a CRITICAL_2H category by a verified account immediately transitions posts.moderation_status to 'PENDING_MOD_SHIELD' inside the synchronous POST /api/v1/safety/reports transaction, hiding the post from public feeds in < 1 second while preserving all evidence for the Grievance Officer to either RESTORE (if false positive) or REMOVE (180-day quarantine hold) in SCR-39.

5.2 Complete End-to-End Journey Audit Matrix (Journeys 1–12)

The table below codifies the transient client state, server-authoritative transaction boundary, idempotency mechanism, race-condition guard, and post-action recovery contract across all 12 core journeys.

Journey Name	Client Transient State (Zustand / IndexedDB)	Server-Authoritative Durable State (Postgres 16 / B2 / Redis)	Transaction Boundary & Idempotency Key	Race-Condition, Orphan & Failure Recovery Contract	Cascade & Revocation Verification
1. Onboarding, 18+ Gate & Recovery (SCR-04–SCR-09)	AUTH_IDLE \rightarrow AUTH_VALIDATING \rightarrow AWAITING_OTP \rightarrow PROFILE_SETUP \rightarrow INTEREST_SEEDING.	auth.users (Supabase) + public.users (onboarding_step = 1..3, consent_version, consented_at) + user_profiles + patch_members.	Single SQL transaction on OTP verify creates users + user_profiles; UNIQUE (LOWER(username)) & UNIQUE (LOWER(email)) prevent duplicates.	<18 DOB fails with 422 ERR_AGE_RESTRICTED and writes zero DB rows. Password reset revokes all refresh tokens and writes active jti claims to Redis denylist.	Middleware redirects any authenticated session with onboarding_step < 3 back to /onboarding.
2. Feed Browsing & Discovery (SCR-11 / SCR-12)	TanStack Query infinite cursor pages (['feed', 'following'], ['feed', 'discover']) + optimistic reaction/mute state.	posts joined with user_profiles, media_assets, co_plots, filtered by user_relationships, patch_members, user_blocks, and user_mutes.	Read-only snapshot (statement_timeout = 5000ms); keyset pagination WHERE p.id < :cursor_uuidv7 ORDER BY p.id DESC LIMIT 20.	Zero OFFSET queries; if Discover ranking query exceeds 150ms, automatically falls back to chronological idx_posts_public_cursor.	Muting a topic or author immediately evicts matching cards from TanStack Query cache and persists in user_mutes.
3. Compose, Upload, Publish, Edit & Delete (SCR-15)	8-state machine (COMPOSER_EMPTY \rightarrow POST_COMMITTED + POST_SUBMIT_ERROR) persisted in IndexedDB draft store.	media_assets (PENDING_UPLOAD \rightarrow VERIFYING \rightarrow READY) in B2 staging/ \rightarrow media/{id}/; posts row committed on publish.	POST /api/v1/posts requires Idempotency-Key: <uuidv4> (cached 24h in Redis) and atomically updates media_assets.post_id = new_post.id WHERE owner_id = :uid AND status = 'READY'.	Per-file xhr.abort() cancels upload and calls DELETE /api/v1/media/{id}. On 201 Created, composer wipes state, revokes blob URLs, and resets <input type="file"> to "".	Soft-deleting a post sets deleted_at = NOW(), purges B2 media/{id}/* objects (unless under moderation_hold), and purges Cloudflare CDN cache.
4. Co-Plot	Optimistic	co_plots,	RSVP acquires	Concurrent	Switching

Journey Name	Client Transient State (Zustand / IndexedDB)	Server-Authoritative Durable State (Postgres 16 / B2 / Redis)	Transaction Boundary & Idempotency Key	Race-Condition, Orphan & Failure Recovery Contract	Cascade & Revocation Verification
Creation, RSVP & Slide Contribution (SCR-13, SCR-17)	RSVP_SAVING state; contributor slide upload tray (1–3 images); host approval drawer state.	co_plot_participants (GOING, MAYBE, DECLINED), conversations (CO_PLOT_THREAD), and media_assets (contributor_id).	SELECT ... FOR UPDATE on co_plots, verifies going_count < capacity, upserts participant, updates going_count, and grants conversation_participants access in one transaction.	capacity overflow returns 409 ERR_PLOT_FULL and reverts client button. Mutual slide uploads auto-attach (MUTUALS_AUTO); non-mutual uploads enter PENDING_APPROVAL for SCR-17 review.	RSVP to DECLINED decrements going_count, sets conversation_participants.state = 'LEFT', and publishes ws.revoke_subscription to drop active socket access.
5. Reactions, 3-Level Comments & Bookmarks (SCR-13, SCR-23)	Optimistic reaction toggle (debounced 250ms); inline comment reply composer; private bookmark toggle.	post_reactions, comments (CHECK (depth BETWEEN 0 AND 2)), and bookmarks.	INSERT ... ON CONFLICT (post_id, user_id, reaction_code) DO NOTHING (or DELETE) coupled with atomic posts.reaction_count increment/decrement.	Double-tapping reactions cannot corrupt counters due to composite UNIQUE constraint. Commenting at depth > 2 returns 422 ERR_MAX_DEPTH_EXCEEDED.	Deleting a parent comment with child replies sets body = NULL, is_tombstone = TRUE so nested child replies remain readable.
6. Community Membership & Permissions (SCR-03 / SCR-21)	Optimistic Join Patch / Joined pill toggle on Patch header and onboarding cards.	patches (member_count) and patch_members (PRIMARY KEY (patch_id, user_id), role IN ('MEMBER', 'STEWARD')).	Atomic INSERT INTO patch_members ... ON CONFLICT DO NOTHING + member_count update.	Attempting to publish a post with patch_id when not a member returns 403 ERR_NOT_PATCH_MEMBER.	Leaving a Patch removes patch_members row and hides PATCH_ONLY posts from the user's feed immediately.
7. Co-Plot Thread Messaging & Reconnect	OPTIMISTIC_QUEUED bubble (delivery_state	conversations (last_message_id, last_message_	INSERT INTO messages ... ON CONFLICT (conversation_i	On disconnect, client reconnects with exponential	If WebSocket upgrade is blocked or container

Journey Name	Client Transient State (Zustand / IndexedDB)	Server-Authoritative Durable State (Postgres 16 / B2 / Redis)	Transaction Boundary & Idempotency Key	Race-Condition, Orphan & Failure Recovery Contract	Cascade & Revocation Verification
Sync (SCR-13 / Stage 2 SCR-28)	= 'sending') + IndexedDB pendingOutbox during network drops.	at), conversation_participants (last_read_message_id), and messages (UUIDv7 id).	d, sender_id, client_msg_id) DO UPDATE SET body = EXCLUDED.body RETURNING id, created_at committed **before** emitting msg.ack.	backoff (1s, 2s, 4s, 8s + jitter), sends sync.resume with after_msg_id to fetch missed UUIDv7 rows, then flushes pendingOutbox idempotently.	restarts, client falls back seamlessly to POST /api/v1/conversations/{id}/messages + 15s REST cursor polling.
8. Unified Search & Notifications (SCR-19, SCR-31)	Debounced (250ms) search input with AbortController; unread notification badge counter.	posts.search_vector, user_profiles.search_vector, patches GIN indexes; notifications table with UNIQUE (recipient_id, dedupe_key).	Search runs read-only with statement_timeout = 2000ms. Notifications upsert via ON CONFLICT (recipient_id, dedupe_key) DO UPDATE SET actor_count = notifications.actor_count + 1, read_at = NULL.	Rapid typing aborts prior HTTP requests cleanly. Reaction bursts roll up into a single notification row rather than flooding SCR-31.	Search and notification queries strictly exclude rows from user_blocks and soft-deleted/quarantined posts.
9. Privacy, Follow Requests, Block & Mute (SCR-23, SCR-33)	Immediate optimistic removal of blocked user's content from client caches; confirmation dialog when toggling Private \rightarrow Public.	user_profiles.is_private, user_relationships (PENDING vs ACCEPTED), user_blocks, and user_mutes.	Blocking executes a single atomic transaction: inserts user_blocks, deletes user_relationships in both directions (A \leftrightarrow B), decrements follower/following counts, removes	Toggling is_private from TRUE to FALSE prompts explicit confirmation and batch-updates pending follow requests to ACCEPTED (triggering is_mutual calculation).	Blocking immediately publishes ws.revoke_subscription to sever any open WebSocket room shared with the blocked user and returns 404 on all direct API lookups.

Journey Name	Client Transient State (Zustand / IndexedDB)	Server-Authoritative Durable State (Postgres 16 / B2 / Redis)	Transaction Boundary & Idempotency Key	Race-Condition, Orphan & Failure Recovery Contract	Cascade & Revocation Verification
			blocked user from host's Co-Plots, and invalidates Redis block sets.		
10. Statutory Moderation, Quarantine & Appeals (SCR-36, SCR-38, SCR-39)	Reported item immediately collapses into REPORTED_HIDDEN shield in reporter's viewport; copyable ticket ID displayed.	safety_reports (ticket_number, sla_tier, sla_deadline_at), posts.moderation_status, and append-only audit_events.	Synchronous transaction generates ticket_number, writes safety_reports + audit_events, and **if sla_tier == 'CRITICAL_2H'**, immediately sets posts.moderation_status = 'PENDING_MOD_SHIELD'.	Ticket number is returned synchronously in the 201 Created HTTP response even if the async email acknowledgment task is delayed.	Removed content (moderation_status = 'REMOVED') is hidden from all public/user routes while its encrypted snapshot and B2 object are locked for 180 days per IT Rules Rule 3(1)(g).
11. Data Export & Account Deletion (SCR-33)	Step-up credential verification modal; typing DELETE confirmation; immediate logout across devices.	users.status = 'PENDING_DELETION', deleted_at = NOW(), Redis revoked_jti:{jti}, and scheduled purge task (deleted_at + 14 days).	Atomic transaction sets PENDING_DELETION, hides profile/posts from all queries, revokes Supabase refresh tokens, and schedules hard purge.	Export is rate-limited to 1 request per 24h (429 otherwise) and writes a private ZIP to B2 private/exports/ with a 24h signed GET URL.	After 14 days, hard purge deletes all B2 media objects (except active 180-day statutory legal holds), sets messages.sender_id = NULL, and cascades DELETE FROM users.
12. Provider Outages & Duplicate Submit Recovery (SCR-40)	Service Worker /offline fallback shell; disabled submit buttons during in-flight mutations; exponential	PostgreSQL Idempotency-Key ledger (or Redis 24h TTL) + composite UNIQUE keys across all	Every state-mutating POST checks idempotency or ON CONFLICT before executing side	If Redis is briefly unreachable, API mutations still commit to PostgreSQL and write a row	Service Worker clears all cached feed/bookmark data and unregisters push endpoints

Journey Name	Client Transient State (Zustand / IndexedDB)	Server-Authoritative Durable State (Postgres 16 / B2 / Redis)	Transaction Boundary & Idempotency Key	Race-Condition, Orphan & Failure Recovery Contract	Cascade & Revocation Verification
	backoff.	join/reaction/message tables.	effects.	to outbox_jobs so background tasks never drop silently.	immediately upon POST /api/v1/auth/logout.

F. Architecture and Domain-Model Red Team (The True $0.00/Month Blueprint)

6.1 Challenging the Phase 1 & Phase 2 Infrastructure Stack

To honor the solo builder's mandate to build and launch Swiftradish with **free resources ($0.00/month)**, the architecture must be engineered specifically around 2026 free-tier cloud physics rather than generic paid SaaS assumptions ([RECOMMENDATION], High Confidence). Achieving a reliable $0.00/month production deployment requires resolving four infrastructure bottlenecks identified during the audit. First, to eliminate the SQLAlchemy 2.0 + asyncpg crash on Supabase's shared transaction pooler (port 6543), the canonical database engine factory in backend/src/core/database.py must enforce poolclass=NullPool—delegating connection pooling entirely to Supavisor rather than holding stale double-pooled connections—paired with connect_args={"statement_cache_size": 0, "prepared_statement_cache_size": 0, "prepared_statement_name_func": lambda: f"__asyncpg_{uuid4()}__", "command_timeout": 10}. For Alembic CLI migrations (alembic/env.py), connections must instead target Supabase's Session Mode Pooler (port 5432) so DDL locks and schema migrations run over a persistent session connection on IPv4 or IPv6 networks. Second, because Supabase pauses Free Tier databases after 7 days without activity, the coding agent must commit .github/workflows/supabase-keep-alive.yml in Slice 0, scheduled via cron: '0 9 * * 1,4' (every Monday and Thursday at 09:00 UTC) plus workflow_dispatch, invoking GET https://<api-host>/api/v1/health so the database is queried every 72–96 hours and never pauses.

Third, selecting free compute hosting without OOM kills or 60-second cold starts is solved via a dual-path deployment strategy. Under **Option A (Primary Recommended Zero-Budget Compute)**, the builder provisions an **Oracle Cloud Infrastructure (OCI) Always Free Ampere A1 Arm VM** (ap-hyderabad-1 or ap-mumbai-[span_143](start_span)[span_143](end_span)[span_146](start_span)[span_146](end_span)[span_149](start_span)[span_149](end_span)1), configured strictly within Oracle's June 15, 2026 revised Always Free entitlement of **2 OCPUs and 12 GB RAM** (1,500 OCPU-hours and 9,000 GB-hours/month) with 200 GB block storage and 10 TB/month egress. A single docker-compose.prod.yml on this 12 GB RAM VM runs FastAPI/Uvicorn (2 workers), redis:7-alpine (with appendonly yes), and the arq background worker 24/7 with zero sleep, zero cold starts, unlimited local Redis Pub/Sub commands, and $0.00/month cost. Under **Option B (Card-Free / Regional Capacity Fallback)**, if the builder cannot provision an OCI Arm instance due to regional host capacity or card verification rules, the Next.js frontend deploys to **Vercel Hobby ($0/mo)**, Redis connects to **Upstash Serverless Redis Free Tier ($0/mo, 250 MB,**

500,000 commands/month), and the FastAPI container deploys to **Hugging Face Spaces (Free Docker tier: 2 vCPU / 16 GB RAM)** or **Render Free Web Service (512 MB RAM)**. To ensure Option B never exceeds Upstash's 500k monthly command limit or Render's 512 MB RAM ceiling, the backend supports an environment flag EMBED_WORKER_IN_APP=true that runs background tasks inside FastAPI's asyncio loop triggered by a PostgreSQL outbox_jobs table rather than polling Upstash Redis every second.
Fourth, to overcome cross-continental upload latency and server memory spikes when uploading from India to Backblaze B2's US-West or EU-Central data centers, SCR-15 (State 2: CLIENT_VALIDATING) runs an off-main-thread browser WebWorker using OffscreenCanvas. This worker downscales any image exceeding 204[span_32](start_span)[span_32](end_span)[span_35](start_span)[span_35](end_span)8px on its longest edge to 2048px, encodes it to high-quality WebP (quality = 0.86, compressing a 12 MB smartphone photo to ~350–600 KB in <150ms while stripping client EXIF GPS tags), and streams the compact 400 KB payload to Backblaze B2 via presigned PUT in under 400ms. On POST /api/v1/media/{id}/complete, FastAPI still performs authoritative HeadObject + 4 KB magic-byte inspection, pyvips decompression-bomb checks (<= 8192x8192), strip=True metadata scrubbing, Blurhash computation, and 400w/1080w/2048w variant generation inside asyncio.Semaphore(2).

6.2 Missing Domain & Schema Contracts Added in Phase 3

To make the 14-table schema from Phase 2 100% resilient under zero-budget constraints, two lightweight operational contracts are added to the Alembic baseline ([RECOMMENDATION], High Confidence). First, a durable outbox_jobs table (id UUIDv7 PK, job_type VARCHAR(48), payload JSONB, status VARCHAR(16) CHECK (status IN ('PENDING', 'PROCESSING', 'COMPLETED', 'DEAD_LETTER')), attempts SMALLINT DEFAULT 0, next_run_at TIMESTAMPTZ, last_error TEXT) replaces separate dead_letter_jobs tables and eliminates idle Redis queue polling. All asynchronous jobs (purge_orphan_media, send_statutory_ack_email, execute_account_export, execute_account_hard_purge) are inserted transactionally into outbox_jobs; when running on Upstash (Option B), an in-process asyncio dispatcher wakes up only when a mutation enqueues a job or on a 5-minute sweep interval, consuming fewer than 5,000 Redis commands per month while providing built-in exponential retry (max_tries = 4) and dead-letter inspection. Second, the CHECK constraint on safe[span_89](start_span)[span_89](end_span)ty_reports.sla_tier is updated from ('CRITICAL_24H', 'STANDARD_72H', 'LEGAL_72H', 'GENERAL_15D') to **('CRITICAL_2H', 'STANDARD_36H', 'LEGAL_36H', 'GENERAL_15D')** to enforce India's 2026 IT Rules amendments at the database layer.

6.3 Architecture Component Decision Table

Architectural Component	Phase 1 / Phase 2 Proposal	Phase 3 Final Decision	Rationale & Zero-Budget Impact	Evolution Trigger (When to Upgrade)
Frontend & SSR Host	Next.js App Router on Vercel (0–20/mo)	**Accept:** Next.js App Router on Vercel Hobby ($0.00/mo)	Delivers SSR OpenGraph tags for /p/[postId] deep links with 100 GB	Upgrade to Vercel Pro ($20/mo) or move Next.js container to OCI

Architectural Component	Phase 1 / Phase 2 Proposal	Phase 3 Final Decision	Rationale & Zero-Budget Impact	Evolution Trigger (When to Upgrade)
			free bandwidth and 1M edge requests/mo.	VM only if commercial team seats are needed.
Backend API, WebSockets & Workers	FastAPI + separate arq worker on Railway/Fly ($14–28$/mo)	**Change:** Single deployable FastAPI Modular Monolith + [span_43](start_span)[span_43](end_span)outbox_jobs on OCI Always Free 2-OCPU / 12 GB Arm VM ($0.00/mo) or Render	Eliminates $14–28/mo compute bill while preserving stateful WebSockets and background job durability.	Split arq workers into separate containers only when concurrent uploads exceed 50/minute.
Database & Search	Supabase Postgres 16 ($0 dev \rightarrow $25/mo Pro before beta)	**Change:** Supabase Free Tier ($0.00/mo, 500 MB DB) + GitHub Actions 72h Keep-Alive Cron + NullPool port 6543 fix	Keeps beta 100% free while preventing the 7-day inactivity pause and fixing the asyncpg prepared-statement crash.	Upgrade to Supabase Pro ($25/mo) when active database size crosses 400 MB (approx. 50,000+ posts).
Media Object Storage & CDN	Phase 1: Cloudflare R2; Phase 2: Backblaze B2 + Cloudflare Worker ($0/mo \le 10\text{ GB})	**Accept Phase 2 + Add Browser WebWorker Pre-Resize:** Backblaze B2 (10 GB free) + Cloudflare Worker CDN ($0.00/mo)	Honors user's B2 bucket, cuts India-to-US upload payload size by 90% via client WebP pre-compression, and achieves $0 egress.	If B2 storage exceeds 10 GB, overage is just $0.006/GB/mo$ (0.06 for an extra 10 GB).
Realtime Pub/Sub & Rate Limiting	Managed Redis ($10/mo)	**Change:** Local redis:7-alpine on OCI VM ($0.00/mo or Upstash 0.00/mo, 500k cmds/mo)	Eliminates the $10/mo fixed Redis fee while supporting WebSocket room fanout, ws_ticket nonces, and sliding-window rate limits.	Move to paid Redis ($10/mo) only if using Upstash and monthly commands exceed 450,000.

G. Security, Privacy, Trust/Safety, and Legal Red Team

7.1 Severity-Ranked Threat Model and Abuse Audit

Every security, privacy, and abuse vector across the Swiftradish surface has been audited for exploitability, impact, mitigation, and automated verification.

Finding ID & Threat Vector	Severity & Launch Blocker?	Plausible Abuse Scenario & Exploit Mechanism	Required Architectural Mitigation	Mandatory Automated Test / Verification Gate	Confidence & Source
SEC-01: Broken Object-Level Authorization (BOLA / IDOR)	**Critical** (Launch Blocker)	Attacker passes another user's media_id to POST /api/v1/posts, reads a private profile's posts, or calls POST /api/v1/plots/{id}/submissions/{subId}/decide on someone else's Co-Plot.	Enforce **Two-Plane Authorization** in every service method: Plane 1 checks RBAC role; Plane 2 enforces SQL-level ownership (owner_id = :uid), visibility (PUBLIC, FOLLOWERS, MUTUALS, PATCH_ONLY), and bidirectional NOT EXISTS (SELECT 1 FROM user_blocks ...). Always return 404 Not Found (never 403) on private objects.	pytest BOLA matrix executing cross-user read, update, delete, RSVP, slide-approve, and media-attach requests across all 14 tables.	**High** ([VERIFIED])
SEC-02: JWT Algorithm Confusion (CVE-2026-10266) & JWKS SSRF	**Critical** (Launch Blocker)	Attacker signs a forged token with alg: "HS256" using Supabase's public ES256 key as the HMAC secret, or injects a rogue iss URL to trigger SSRF	Pin SUPABASE_JWKS_URL and EXPECTED_ISSUER strictly from server environment variables (never read iss from unverified token payload);	Unit/integration test suite testing alg: none, alg: HS256 with public key, wrong iss/aud, expired tokens, and revoked jti.	**High** ([VERIFIED])

Finding ID & Threat Vector	Severity & Launch Blocker?	Plausible Abuse Scenario & Exploit Mechanism	Required Architectural Mitigation	Mandatory Automated Test / Verification Gate	Confidence & Source
		from FastAPI.	enforce algorithms=["ES256"] and audience="authenticated" in PyJWT; check Redis revoked_jti:{jti} on all state mutations and WebSocket ticket minting.		
SEC-03: Decompression Bombs, Polyglots, OOM & EXIF GPS Leaks	**Critical** (Launch Blocker)	Attacker uploads an SVG with embedded <script>, a JPEG-polyglot, a 100,000 \times 100,000\text{px} PNG bomb to crash the 512 MB/12 GB server, or leaks a user's home GPS coordinates via raw EXIF.	Ban SVG uploads (415); sign Content-Type and Content-Length <= 15728640 into B2 presigned PUT; guard server complete with asyncio.Semaphore(2); verify first 4 KB magic bytes; check pyvips header width <= 8192 AND height <= 8192 before buffer allocation; strip all metadata (strip=True); re-encode into clean WebP containers; serve from cdn.swiftradish.app with Content-Securit	Upload security suite testing EICAR, SVG-in-JPEG polyglot, 100 MP header bomb (422), and GPS-tagged JPEG (asserting zero EXIF GPS tags in output WebP).	**High** ([VERIFIED])

Finding ID & Threat Vector	Severity & Launch Blocker?	Plausible Abuse Scenario & Exploit Mechanism	Required Architectural Mitigation	Mandatory Automated Test / Verification Gate	Confidence & Source
			y-Policy: default-src 'none' and X-Content-Type-Options: nosniff.		
SEC-04: Private B2 Bucket Enumeration & Expired CORS Leakage	**High** (Launch Blocker)	Attacker enumerates predictable file paths on Backblaze B2, accesses deleted post media cached at the CDN edge, or steals a long-lived presigned URL.	Set B2 bucket to allPrivate; use unguessable UUIDv7 keys (media/{uuidv7}/feed_1080w.webp); restrict Cloudflare Worker Application Key strictly to readFiles on the media/ prefix (never staging/ or private/); cap presigned PUT/GET TTL at 15 minutes; trigger B2 DeleteObject + Cloudflare Cache Purge API on post deletion.	Integration test verifying direct B2 URL returns 401/403, staging/ prefix is unreadable via CDN Worker (404), and deleted media purges cleanly.	**High** ([VERIFIED])
SEC-05: Real-Time Block Bypass & WebSocket Exhaustion	**High** (Launch Blocker)	User B stays connected to a Co-Plot WebSocket room after being blocked by Host A or kicked from the Co-Plot, or opens 500	Authenticate /ws via 30s single-use Redis nonce (GETDEL ws_ticket:{nonce}); enforce max 5 concurrent sockets per	Playwright + WebSocket integration test verifying that blocking a user mid-chat drops their room subscription within <200ms and rejects	**High** ([VERIFIED])

Finding ID & Threat Vector	Severity & Launch Blocker?	Plausible Abuse Scenario & Exploit Mechanism	Required Architectural Mitigation	Mandatory Automated Test / Verification Gate	Confidence & Source
		sockets to exhaust server memory.	user (closing oldest with 4008); re-verify conversation_participants and user_blocks on every room.subscribe and msg.send frame; publish ws.[span_121](start_span)[span_121](end_span)revoke_subscription on block or RSVP decline to sever active room subscriptions immediately.	subsequent msg.send frames.	
SEC-06: Weaponized False Reporting vs. 2-Hour Statutory Takedown	**High** (Launch Blocker)	Because CRITICAL_2H reports trigger instant automated quarantine (PENDING_MOD_SHIELD) to comply with India's 2-hour IT Rules clock, a troll could falsely report legitimate Co-Plots as CRITICAL_2H to censor them.	Require verified email + active account to trigger instant single-report PENDING_MOD_SHIELD; notify the Grievance Officer immediately via high-priority email/webhook; provide 1-click Restore & Penalize False Reporter macro in SCR-39 (which strips the false reporter's auto-shield	Integration test verifying: (a) trusted user CRITICAL_2H report hides post in <1s, and (b) admin Restore macro restores post visibility and disables reporter's instant-shield privilege.	**High** ([RECOMMENDATION])

Finding ID & Threat Vector	Severity & Launch Blocker?	Plausible Abuse Scenario & Exploit Mechanism	Required Architectural Mitigation	Mandatory Automated Test / Verification Gate	Confidence & Source
			trust flag and logs an audit_events violation).		
SEC-07: Free-Tier Quota Exhaustion / Spend Attack	**High** (Launch Blocker)	Automated scripts flood /api/v1/media/upload-intents, /api/v1/auth/register (burning Resend's 3,000 free monthly emails), or search endpoints.	Enforce sliding-window rate limits per IP and user (5 auth req / 15m, 20 media intents / 1h, 10 posts / 1h, 40 searches / 1m); integrate free **Cloudflare Turnstile** on /register, /login, and /legal/grievance; provide a Redis/env kill-switch (UPLOADS_ENABLED=false, INVITE_ONLY=true).	Rate-limit integration test asserting HTTP 429 + Retry-After header on the (N+1)\text{th} request across auth, upload, and search routes.	**High** ([VERIFIED])

7.2 High-Priority Legal & Policy Red Team (India DPDP Act 2023, DPDP Rules 2025 & IT Rules 2021–2026)

In accordance with Section 4 of the audit mandate, every legal assertion in Phase 1 and Phase 2 has been cross-checked against primary Indian statutory texts and MeitY notifications ([VERIFIED], High Confidence). This audit separates binding statutory obligations from conservative product design choices and does not constitute formal legal advice.

Blueprint / Phase 2 Legal Claim	Primary Indian Statutory Text & Current Status (Oct 2026)	Applicability to Swiftradish & Audit Verdict	Statutory Obligation vs. Conservative Product Design	Mandatory Technical / Workflow Correction
Claim 1: Section 9 of the DPDP Act 2023 mandates an 18+ age gate at launch because	**DPDP Act 2023 Sec 9 & DPDP Rules 2025 (notified Nov 13–14, 2025 via**	**Partially Confirmed (Conservative Design Choice):** The statute does	**Product Policy Choice:** Rejecting <18 DOB at /register. **Legal Ambiguity:**	Retain strict 18+ DOB check at /register (HTTP 422 on <18 with zero DB

Blueprint / Phase 2 Legal Claim	Primary Indian Statutory Text & Current Status (Oct 2026)	Applicability to Swiftradish & Audit Verdict	Statutory Obligation vs. Conservative Product Design	Mandatory Technical / Workflow Correction
processing data of anyone <18 requires verifiable parental consent.	**G.S.R. 843(E)/846(E)):** Defines a "child" as any individual under 18 years of age and requires Data Fiduciaries to obtain verifiable consent of the parent/guardian (using reliable identity/age details or virtual tokens via Digital Locker / authorized entities) before processing a child's personal data; prohibits tracking/behavioral monitoring of children. Substantive enforcement takes effect May 13–14, 2027 (subject to Jan 2026 consultation).	*not* ban <18 users; rather, it requires verifiable parental consent if <18 users are admitted. For a solo builder with $0 KYC budget, restricting the platform to **18+ adults only** (SCR-04) is a **conservative product policy choice** to avoid processing children's data altogether.	Whether self-declared DOB at registration is sufficient to prove a platform is not knowingly processing children's data, or whether adult-only platforms must eventually verify adulthood via DigiLocker tokens.	persistence), prohibit behavioral ad tracking platform-wide, and flag DigiLocker age-token verification for Indian legal counsel prior to commercial scaling.
Claim 2: DPDP Act 2023 requires an itemized consent notice and 72-hour breach reporting.	**DPDP Act 2023 Sec 5, 6, 8(6) & DPDP Rules 2025 Rule 7:** Eliminates GDPR-style "legitimate interest"; requires free, specific, informed, unconditional, and unambiguous consent preceded by an itemized notice (accessible in English and the 22 Eighth	**Confirmed (Binding Obligation upon commencement):** Applies to all Data Fiduciaries processing digital personal data in India, regardless of size. Note that until May 2027, the IT Act 2000 & SPDI Rules 2011 continue to apply in parallel.	**Statutory Obligation:** Itemized notice, withdrawal mechanism, erasure upon withdrawal, and 72h breach reporting. **Misconception Corrected:** Having consent_version in PostgreSQL is *not* legal compliance unless backed by actual itemized	Ship standalone itemized consent checkbox on SCR-04, 1-click consent withdrawal / account deletion in SCR-33, and an admin Breach Notification Dispatch script in SCR-39 that exports the DPB 72h report and emails affected users.

Blueprint / Phase 2 Legal Claim	Primary Indian Statutory Text & Current Status (Oct 2026)	Applicability to Swiftradish & Audit Verdict	Statutory Obligation vs. Conservative Product Design	Mandatory Technical / Workflow Correction
	Schedule languages). Rule 7 mandates notifying the Data Protection Board (DPB) and every affected Data Principal within **72 hours** of becoming aware of a personal data breach, with **zero materiality threshold**.		notice text and working erasure/breach workflows.	
Claim 3: India IT Rules 2021 require 24h grievance acknowledgment, **24h** takedown for Rule 3(2)(b) privacy / impersonation complaints, **72h** takedown for Rule 3(1)(b) user complaints and law enforcement orders, and 15-day general resolution.	**IT (Intermediary Guidelines and Digital Media Ethics Code) Rules, 2021 (as amended Oct 2022, Apr 2023, and by the IT Amendment Rules, 2026):** While acknowledgment remains \le 24\text{ hours} and general grievance resolution remains \le 15\text{ days}, the **2026 Amendments** drastically tightened expedited takedowns: sensitive complaints under **Rule 3(2)(b)** (severe privacy violations, deepfakes, or	**Outdated in Phase 1 & Phase 2 (Critical Legal Correction):** Rule 3 applies to *all* intermediaries (not just SSMIs with >50 lakh users) to retain safe-harbor immunity under Section 79 of the IT Act, 2000. A solo builder cannot manually meet a 2-hour takedown clock 24/7 without automated quarantine.	**Statutory Safe-Harbor Obligation:** Appointing a Grievance Officer (Rule 3(2)), meeting the 2h / 36h / 15d clocks, preserving removed records for **180 days** (Rule 3(1)(g)), and informing users of their 30-day right to appeal to the Grievance Appellate Committee (gac.gov.in, Rule 3A).	Rename SLA tiers to **CRITICAL_2H** and **STANDARD_36H**. Configure POST /api/v1/safety/reports to automatically place any CR[span_154](start_span)[span_154](end_span)ITICAL_2H reported post into PENDING_MOD_SHIELD in **< 1 second** (disabling public access immediately within the 2-hour legal window) while notifying the Grievance Officer to review and finalize in SCR-39.

Blueprint / Phase 2 Legal Claim	Primary Indian Statutory Text & Current Status (Oct 2026)	Applicability to Swiftradish & Audit Verdict	Statutory Obligation vs. Conservative Product Design	Mandatory Technical / Workflow Correction
	impersonation) were cut from **24 hours to 2 hours**, and **Rule 3(1)(b)** prohibited content timelines were cut from **72 hours to 36 hours**.			
Claim 4: Rule 4(8) requires giving the author notice and an opportunity to dispute content removal.	**IT Rules 2021 Rule 4(8) vs. Rule 3(1)(b) & GAC Principles:** Statutorily, Rule 4 applies only to Significant Social Media Intermediaries (**SSMIs**, \ge 50\text{ lakh} / 5 million registered users in India). However, the Grievance Appellate Committee (gac.gov.in) expects natural-justice notice and reason disclosures on content takedowns.	**Partially Confirmed:** Not a statutory Rule 4 mandate below 50 lakh users, but a high-value **conservative product design** that reduces GAC appeals and protects user trust.	**Conservative Product Design:** Providing takedown reason notice and an in-app appeal form (SCR-38) to all users from Day 1.	Retain SCR-38 takedown notification and appeal form, plus explicit link to https://gac.gov.in.
Claim 5: Account deletion purges all user data and B2 media after a 14-day grace window.	**DPDP Act Sec 12(3) (Right to Erasure) vs. IT Rules 2021 Rule 3(1)(g) (180-Day Statutory Preservation) & CERT-In Directions (180-Day Log Retention):** Data	**Conflict Identified & Resolved:** An unconditional 14-day hard purge would allow an abuser to upload unlawful content, get reported, immediately delete their account, and destroy evidence	**Statutory Override:** Legal preservation under IT Rules Rule 3(1)(g) and DPDP Sec 12(3) overrides the user's 14-day erasure request for flagged records.	In execute_account_hard_purge, check moderation_hold == TRUE or active safety_reports: purge all normal profile/post/media data at Day 14, but isolate any flagged evidence snapshot

Blueprint / Phase 2 Legal Claim	Primary Indian Statutory Text & Current Status (Oct 2026)	Applicability to Swiftradish & Audit Verdict	Statutory Obligation vs. Conservative Product Design	Mandatory Technical / Workflow Correction
	Fiduciaries must erase personal data upon consent withdrawal *unless retention is necessary for compliance with any law for the time being in force*. Rule 3(1)(g) mandates preserving removed unlawful content and associated records for **180 days** for investigation.	after 14 days in violation of Rule 3(1)(g).		and B2 object in an encrypted legal_quarantine/ prefix with a mandatory **180-day TTL** before final destruction.

7.3 Counsel-Review Checklist Before Commercial Scaling

Before transitioning Swiftradish from a closed student/hobbyist beta to a commercial public service in India, the founder must present five operational questions to qualified Indian legal counsel ([RECOMMENDATION], High Confidence). First, counsel must confirm whether self-declared Date of Birth (\ge 18) at registration (SCR-04) paired with explicit Terms of Service prohibiting minors satisfies Section 9 of the DPDP Act 2023, or whether MeitY guidance requires adult-only social platforms to integrate DigiLocker age-token verification. Second, counsel must review the standalone itemized DPDP Consent Notice (SCR-04) and Privacy Policy and advise on the rollout schedule for translations across the 22 Eighth Schedule languages. Third, counsel must verify the public disclosure format on /legal/grievance (Name, Designation, Email, Physical Address in India) under IT Rules Rule 3(2) and confirm monitoring thresholds for the 50 lakh user SSMI boundary (Rule 4) and the 2 crore user DPDP Third Schedule retention boundary. Fourth, counsel must confirm that Swiftradish's instant automated quarantine (PENDING_MOD_SHIELD within <1\text{ second} of a CRITICAL_2H complaint, followed by human Grievance Officer adjudication) satisfies the 2-hour disablement requirement under the 2026 IT Rules amendments (Rule 3(2)(b)). Finally, counsel must approve the pre-drafted notification templates for CERT-In (6-hour cybersecurity incident reporting) and DPB Rule 7 (72-hour personal data breach reporting).

H. Reliability, Performance, Observability, and Test Gates

8.1 Audited Performance Targets vs. Sourced Benchmarks

All performance claims in Phase 1 and Phase 2 have been audited to separate empirical benchmarks from **Target Service-Level Objectives (SLOs)**. Every target below specifies its exact measurement location, percentile, test environment, CI release gate, and degraded-mode fallback ([RECOMMENDATION], High Confidence).

Metric & Definition	Target Budget & Percentile	Measurement Location & Tooling	Test Environment & Method	Automated CI Release Gate	Degraded-Mode / Outage Fallback	Basis & Confidence
Initial Route Load (LCP / CLS / JS Bundle)	\text{LCP} \le 1.8\text{s} (p75), \text{CLS} \le 0.03, Initial JS \le 140\text{ KB} gzipped.	Browser Navigation Timing API + Lighthouse CI + @next/bundle-analyzer.	GitHub Actions runner emulating Moto G Power (4x CPU throttle, Slow 4G RTT 150ms) against /, /home, and /p/[postId].	Build fails if any initial route bundle exceeds 140 KB gzipped or Lighthouse CLS > 0.03.	Server-stored width, height, and 32-char blurhash canvas prevent layout shift even when CDN image delivery is degraded.	**Target SLO** (High Confidence)
Interaction to Next Paint (INP) & Optimistic Feedback	\text{INP} \le 120\text{ms} (p75); optimistic toggle render \le 16\text{ms} (1 frame).	Playwright Performance Observer trace during RSVP, reaction, and slide switch.	Desktop Chromium (1440x900) and Mobile WebKit (390x844) with 60 feed cards mounted.	Playwright test fails if reaction or tab switch blocks main thread > 120\text{ms}.	Offscreen feed cards unmount high-res textures via @tanstack/react-virtual when list exceeds 40 items.	**Target SLO** (High Confidence)
REST API Latency & SQL Query Count	Reads (GET /feed/*, GET /posts/{id}): \text{p95} \le 90\text{ms}, \text{p99} \le 200\text{ms}. Writes: \text{p95} \le 160\text{ms}. SQL queries per request: \le 3 (strictly 0\text{ N+1}).	FastAPI structlog timing middleware + SQLAlchemy before_cursor_execute query counter.	pytest integration suite + k6 synthetic load test (50 VUs for 2 minutes against Docker/staging).	pytest fails immediately if GET /api/v1/feed/following executes > 3 SQL statements (lazy="raise" enforced on all ORM models).	Supavisor/PgBouncer enforces command_timeout = 10s and statement_timeout = 5000ms; Discover feed falls back to chronological index if ranking query exceeds 150ms.	**Target SLO** (High Confidence)

Metric & Definition	Target Budget & Percentile	Measurement Location & Tooling	Test Environment & Method	Automated CI Release Gate	Degraded-Mode / Outage Fallback	Basis & Confidence
Media Upload & Server Verification (complete)	Browser WebWorker pre-resize: \le 200\text{ms}. Server POST /media/{id}/complete: \text{p95} \le 650\text{ms}, peak worker RSS memory delta \le 120\text{ MB}.	Server timer histogram around asyncio.Semaphore(2) + pyvips worker thread.	Integration test uploading 5 concurrent pre-resized WebP/JPEG files (~500 KB–4 MB each).	Test fails if complete p95 exceeds 1000ms or container RSS grows by > 150\text{ MB}.	If asyncio.Semaphore(2) waits > 2.0\text{s}, returns 202 Accepted (status = 'VERIFYING'), writes an outbox_jobs task, and client polls GET /media/{id}/status every 1.5s.	**Target SLO** (High Confidence)
WebSocket Fanout & Reconnect Gap Sync	msg.send \rightarrow Postgres commit \rightarrow msg.ack / msg.new: \text{p95} \le 150\text{ms}. Reconnect sync.resume: \text{p95} \le 200\text{ms}.	k6 WebSocket test + Playwright offline/online network toggle test.	Two concurrent Playwright browser contexts in a Co-Plot thread; Context B drops offline for 10s while Context A sends 3 messages.	Release blocked if reconnect produces >0 duplicate message bubbles or drops any queued message.	If WebSocket connection fails 3 consecutive handshakes, client automatically switches to POST /messages + 15s REST cursor polling with an honest status pill.	**Target SLO** (High Confidence)
Statutory Report Quarantine & Ticket Ack	CRITICAL_2H public quarantine (PENDING_MOD_SHIELD): **Synchronous (\le 200\text{ms})**. Ticket ID generation: **Synchronou**	safety_reports & audit_events commit timestamps + outbox_jobs lag metric.	Integration test submitting a CRITICAL_2H report and immediately querying GET /api/v1/posts/{id} as a second user.	Test fails if reported CRITICAL_2H post remains visible to public callers for >0\text{ms} after POST /safety/reports returns	Synchronous DB commit guarantees immediate quarantine and returns ticket_number in the 201 response even if the email provider	**Statutory Gate** (High Confidence)

Metric & Definition	Target Budget & Percentile	Measurement Location & Tooling	Test Environment & Method	Automated CI Release Gate	Degraded-Mode / Outage Fallback	Basis & Confidence
	s (\le 200\text{ms}). Email ack dispatch: \text{p99} \le 60\text{s}.			201.	(Resend) is down.	

8.2 Release-Gate Checklist (Preventing "Visually Complete" Hallucinations)

A slice or feature branch (feat/slice-*) is strictly blocked from merging to main unless the coding agent produces terminal execution output confirming all six release gates ([RECOMMENDATION], High Confidence). First, under **Gate 1 (Migration Reversibility & Preflight — AUTOMATED-TESTED)**, alembic upgrade head && alembic downgrade -1 && alembic upgrade head must exit 0 against a real PostgreSQL 16 instance (Base.metadata.[span_49](start_span)[span_49](end_span)create_all() is banned across the repository), and the FastAPI lifespan startup hook must halt boot if alembic_version mismatches HEAD. Second, under **Gate 2 (Static Typing & Lint Cleanliness)**, ruff check ., mypy --strict src, pnpm eslint ., and pnpm tsc --noEmit must exit 0 with zero warnings or suppressed @ts-ignore directives. Third, under **Gate 3 (Two-Plane BOLA & Security Matrix — SECURITY-REVIEWED)**, pytest tests/security/test_bola_matrix.py must verify that User B receives 404 Not Found when attempting to read, mutate, or attach User A's private profiles, posts, media assets, Co-Plot queues, or blocked resources. Fourth, under **Gate 4 (Real-Storage Upload & Orphan Cleanup — INTEGRATION-VERIFIED)**, pytest tests/modules/test_media_pipeline.py must verify presigned PUT, 4 KB magic-byte validation, EXIF GPS removal, SVG/polyglot rejection (422), and 6-hour unattached media cleanup. Fifth, under **Gate 5 (Browser E2E & Accessibility — BROWSER-VERIFIED)**, Playwright E2E tests must pass at both 1440x900 (Desktop) and 390x844 (Mobile) viewports with zero @axe-core/playwright WCAG 2.2 AA violations and verified post-action state reset. Sixth, under **Gate 6 (Privacy-Safe Observability & Backup Drill)**, structlog output tests must confirm zero leakage of JWTs, cookies, passwords, OTPs, raw emails, or message bodies in logs, and scripts/backup_db_to_b2.sh must successfully write an age-encrypted pg_dump to the B2 backups/ prefix.

I. Independent Cost and Capacity Stress Test ($0.00/Month to Scaled Traction)

9.1 Recalculated 2026 Mathematical Cost Model and Free-Tier Boundaries

Unlike Phase 1 ($49–69/mo) and Phase 2 ($24–49/mo), which assumed paid compute and Redis from Day 1, the Phase 3 financial model proves that Swiftradish can be built, tested, and operated through its entire **1,000 MAU / 250 DAU Seed Launch for $0.00/month**, using explicit mathematical formulas tied to verified October 2026 free-tier quotas ([VERIFIED], High

Confidence).
Let M denote Monthly Active Users (MAU), D denote Daily Active Users (DAU), P_{\text{mo}} denote new posts/Co-Plots published per month, and I_{\text{post}} = 3.0 denote average images per post. After client-side WebWorker pre-compression and server-side pyvips generation of three optimized WebP variants (thumb_400w \approx 30\text{ KB}, feed_1080w \approx 140\text{ KB}, full_2048w \approx 330\text{ KB}, deleting the staging/ upload immediately), each image consumes S_{\text{img}} = 0.50\text{ MB} across all three variants (1.50\text{ MB} per 3-image post):
\Delta V_{\text{B2_GB/mo}} = \frac{P_{\text{mo}} \times I_{\text{post}} \times 0.50\text{ MB}}{1024} \text{Monthly Media Cost (B2 + CF Worker)} = \max\left(0, V_{\text{total_GB}} - 10\right) \times \$0.006 + \max\left(0, R_{\text{uncached_mo}} - 75,000\right) \times \frac{\$0.004}{10,000} + \$0.00\text{ (Egress)}
For PostgreSQL 16 storage on Supabase (500 MB free limit), each post + Co-Plot + 3 media_assets rows + 5 comments + 10 reactions + GIN tsvector/pg_trgm index entries consumes approximately K_{\text{post}} \approx 6.5\text{ KB} of relational disk space:
V_{\text{DB_MB}} = \text{Base Schema Overhead (35 MB)} + \frac{N_{\text{total_posts}} \times 6.5\text{ KB} + N_{\text{total_messages}} \times 0.8\text{ KB}}{1024}
Thus, Supabase's 500 MB Free Tier safely holds **\approx 50,000 rich posts and 150,000 Co-Plot chat messages** before approaching the 400 MB upgrade trigger, provided read notifications older than 60 days and completed outbox_jobs older than 7 days are pruned nightly ([INFERENCE], High Confidence).

9.2 Low, Base, and High Scenario Cost Breakdown & Sensitivity Table

Infrastructure Layer & Provider	Low Scenario: Seed Launch (1,000 MAU / 250 DAU, 1,500 posts/mo)	Base Scenario: Growing Community (10,000 MAU / 3,000 DAU, 20,000 posts/mo)	High Scenario: Scaled Traction (50,000 MAU / 15,000 DAU, 120,000 posts/mo)	Free-Tier Ceiling, Dominant Cost Driver & Hard Guardrail
1. Frontend & SSR (Next.js App Router)	**$0.00/mo** (Vercel Hobby Free Tier: 100 GB bandwidth, 1M edge requests).	**$0.00/mo** (Vercel Hobby or served from OCI VM behind Cloudflare CDN).	**$20.00/mo** (Vercel Pro or 2x Docker SSR containers).	**Free Ceiling:** 100 GB Vercel transfer. **Guardrail:** All media served from cdn.swiftradish.app, never through Next.js image optimizer (unoptimized: true with custom loader).
2. Backend API, WebSockets & Workers (FastAPI + outbox_jobs)	**$0.00/mo** (OCI Always Free 2-OCPU / 12 GB RAM Arm VM; or Render/HF Free).	**$0.00/mo** (OCI Always Free 2-OCPU / 12 GB RAM Arm VM easily handles 3,000 DAU & ~600	**$45.00/mo** (OCI Arm VM + 2x paid 2-vCPU/4GB overflow worker nodes on Hetzner/Railway).	**Free Ceiling:** 1,500 OCPU-hrs & 9,000 GB-hrs/mo on OCI. **Guardrail:** asyncio.Semaphor

Infrastructure Layer & Provider	Low Scenario: Seed Launch (1,000 MAU / 250 DAU, 1,500 posts/mo)	Base Scenario: Growing Community (10,000 MAU / 3,000 DAU, 20,000 posts/mo)	High Scenario: Scaled Traction (50,000 MAU / 15,000 DAU, 120,000 posts/mo)	Free-Tier Ceiling, Dominant Cost Driver & Hard Guardrail
		concurrent sockets).		e(2) on pyvips + max 5 sockets/user.
3. Primary Database & Auth (Supabase Postgres 16 + Auth)	**$0.00/mo** (Supabase Free Tier: 500 MB DB, 50k MAU Auth + GitHub Actions 72h Keep-Alive Cron).	**$25.00/mo** (Supabase Pro base: 8 GB DB included, 100k MAU included, $10 compute credit covers Micro instance, Spend Cap ON).	**$65.25/mo** (Supabase Pro $25 + Small Compute add-on $35 + ~48 GB DB storage = $5.25; 50k MAU included in 100k cap).	**Free Ceiling:** 500 MB DB disk. **Guardrail:** Nightly cron deletes read notifications >60\text{d} and completed outbox_j[span_175](start_span)[span_175](end_span)[span_177](start_span)[span_177](end_span)[span_179](start_span)[span_179](end_span)obs >7\text{d}; Supabase **Spend Cap ON** by default.
4. Media Object Storage & Delivery (Backblaze B2 + Cloudflare Worker CDN)	**$0.00/mo** (\approx 2.25\text{ GB/mo} added; < 10\text{ GB} B2 free tier; \approx 28\text{k} uncached Class B reads < 75\text{k/mo} free cap; $0 egress).	**$1.18/mo** (\approx 150\text{ GB} billable over 10 GB free \times \$0.006 = \$0.90 + 700k uncached reads = $0.28; 1.8 TB Cloudflare CDN egress = $0.00).	**$8.60/mo** (\approx 1,090\text{ GB} billable \times \$0.006 = \$6.54 + 5.2M uncached reads = $2.06; 14 TB CDN egress = $0.00).	**Free Ceiling:** 10 GB B2 storage + 2,500 Class B reads/day + 100k Cloudflare Worker req/day. **Guardrail:** Set B2 hard storage cap alert at $2.00/mo and Cache-Control: immutable.
5. Redis, Transactional Email & Monitoring (Redis 7, Resend, Sentry)	**$0.00/mo** (Local Redis on OCI VM or Upstash Free 500k cmds/mo; Resend Free 3,000 emails/mo; Sentry Developer	**$6.00/mo** (Local Redis on OCI $0; Resend overage / starter for OTPs; Sentry Free).	**$10.00/mo** (Dedicated Redis replica + Resend $10/mo tier).	**Free Ceiling:** 3,000 emails/mo (100/day) on Resend. **Guardrail:** Enable Google OAuth on SCR-04/SCR-05

Infrastructure Layer & Provider	Low Scenario: Seed Launch (1,000 MAU / 250 DAU, 1,500 posts/mo)	Base Scenario: Growing Community (10,000 MAU / 3,000 DAU, 20,000 posts/mo)	High Scenario: Scaled Traction (50,000 MAU / 15,000 DAU, 120,000 posts/mo)	Free-Tier Ceiling, Dominant Cost Driver & Hard Guardrail
	Free).			so OAuth sign-ups consume **0 OTP emails**.
Total Monthly Infrastructure Run-Rate	**$0.00 / month** (100% Free Resource Target Achieved)	**$32.18 / month** ($0.0032 per MAU — 72% cheaper than Phase 2)	**$148.85 / month** ($0.0030 per MAU — 60% cheaper than Phase 2)	Hard billing alerts & spend caps set at $0.00 (Seed), $35.00 (Base), and $160.00 (High).

9.3 Abuse Stress-Test Scenarios and Automated Circuit Breakers

To ensure a malicious actor cannot force the solo builder off the $0.00/month free tiers or trigger surprise overage bills, four automated circuit breakers are built into the backend ([RECOMMENDATION], High Confidence). First, to counter an **Automated Upload Flood** targeting Backblaze B2's 10 GB free cap, FastAPI tracks a global rolling 24-hour byte counter (global_upload_bytes_24h) alongside per-user rate limits (20 files/hour); if total platform uploads in any 24-hour window exceed 1.5 GB during the seed phase, the system automatically flips UPLOADS_THROTTLED=true (restricting uploads to accounts older than 7 days with mutual connections) and alerts the founder. Second, to counter **OTP Email Bombing** targeting Resend's 100 emails/day free cap, /register, /login, and /auth/reset-password require a free invisible **Cloudflare Turnstile** token, enforce a strict IP sliding window of 3 OTP emails per 30 minutes, and feature **1-tap Google OAuth** as the primary button on SCR-04/SCR-05 so OAuth sign-ups verify email with zero outbound emails. Third, to counter **Cache-Busting Query String Attacks** (?bust=1..50000) targeting B2's 2,500/day Class B read cap and Cloudflare's 100k/day Worker cap, the Cloudflare Delivery Worker strips all URL query parameters (url.search = "") before checking caches.default and validates that the path matches ^\/media\/[0-9a-f-]{36}\/(thumb_400w|feed_1080w|full_2048w)\.webp$, rejecting all other requests at the edge with 404 before touching B2. Fourth, to prevent a **Retry Storm During Container Wake-Up**, client WebSocket and TanStack Query retry logic enforces full jitter exponential backoff:
$$t_{\text{sleep}} = \text{random}\left(0, \min\left(30\text{s}, 1.5\text{s} \times 2^{\text{attempt}}\right)\right)$$
and pauses all network retries whenever navigator.onLine === false or document.visibilityState === 'hidden'.

J. Final Implementation Roadmap (Cursor-Friendly Vertical Slices)

10.1 Sequencing Strategy for Cursor Pro (Grok / Composer 2.5)

To prevent context window saturation and multi-file hallucinations in Grok and Composer 2.5, the implementation is partitioned into **Six Dependency-Ordered Vertical Slices (Slices 0–5)** for the 15-screen MVP Core, followed by Stage 2 post-beta slices ([RECOMMENDATION], High Confidence). Each slice delivers a working, persisted, tested end-to-end user capability, modifies **at most 3–5 files per coding-agent prompt**, and includes an explicit **Stop / Rescope Gate** if a sub-task exceeds its time budget.

Slice ID & Milestone	User-Visible Outcome	Included vs. Excluded Scope	Prerequisites & External Services	Domain & API Contracts Delivered	Mandatory Executable Tests & Acceptance Criteria	Rollback, Git Checkpoint & Rescope Gate
Slice 0: Cloud Verification, Zero-Budget Preflight & Repo Baseline (Days 1–2)	Local (docker-compose.yml) and cloud environments boot cleanly; /api/v1/health verifies Supabase port 6543 (NullPool), B2 S3 credentials, and Alembic HEAD match; SCR-01 & SCR-40 render.	**Included:** Git remote link, .gitignore, .env.example, DESIGN.md, AGENTS.md, .github/workflows/supabase-keep-alive.yml, Alembic 0001_init_extensions.py (pg_trgm, outbox_jobs), SCR-01, SCR-40. **Excluded:** Auth, posts, media.	User's GitHub repo (Swiftradish), Supabase project URL/keys (ports 6543 & 5432), Backblaze B2 private bucket & Application Keys.	GET /api/v1/health returning {"status": "ok", "db_revision": "<head>", "storage": "ok"} in <200ms.	pytest tests/core/test_preflight.py verifying: (1) server refuses to boot if DB revision \ne \text{HEAD}; (2) alembic upgrade head && alembic downgrade base && alembic upgrade head passes; (3) 150 concurrent SELECT 1 calls on port 6543 pass with zero DuplicatePreparedStatementError.	**Git Tag:** v0.1.0-slice0. **Rollback:** git revert + alembic downgrade base. **Stop Gate:** Halt if B2 PutObject or Supabase port 6543 fails.
Slice 1: 18+ Auth, ES256 JWKS Verification & Onboarding Identity (Days 3–6)	Users can register (18+ gate + itemized DPDP consent + Turnstile), verify OTP (or Google	**Included:** SCR-04, SCR-05, SCR-06, SCR-07, SCR-08 (Step 1), SCR-33 (Sessions	Slice 0 + Supabase Auth ES256 JWKS URL & Google OAuth client configured.	POST /api/v1/auth/register, POST /api/v1/auth/verify-otp, GET /api/v1/users/check-userna	pytest + Playwright verifying: (a) <18 DOB returns 422 with 0 DB rows; (b) ES256 JWT verified	**Git Tag:** v0.2.0-slice1. **Rollback:** alembic downgrade -1. **Rescope Gate:** If custom Turnstile

Slice ID & Milestone	User-Visible Outcome	Included vs. Excluded Scope	Prerequisites & External Services	Domain & API Contracts Delivered	Mandatory Executable Tests & Acceptance Criteria	Rollback, Git Checkpoint & Rescope Gate
	OAuth), log in, claim a unique @username (SCR-08), and revoke sessions (SCR-33).	tab), users & user_profiles tables. **Excluded:** Avatar upload (Slice 3), Patch seeding (Slice 5).		me, GET/PATCH /api/v1/users/me, DELETE /api/v1/auth/sessions/{id}.	locally in <1ms; (c) HS256 or wrong-iss tokens rejected 401; (d) open-redirect ?next=https://evil.com blocked; (e) E2E signup \rightarrow handle claim passes.	widget stalls >4\text{h}, use Supabase's built-in Captcha toggle in dashboard.
Slice 2: Profiles, Hybrid Social Graph, Private Accounts & Atomic Blocking (Days 7–10)	Users can view/edit dark-first profiles (SCR-23/24), follow public accounts, request to follow private accounts (SCR-25), auto-form Mutual edges, and block/mute users (SCR-33).	**Included:** SCR-23 (with SCR-24 & SCR-25 drawers), SCR-33 (Privacy/Blocks tab), user_relationships, user_blocks, user_mutes. **Excluded:** Posts and media.	Slice 1 completed.	GET /api/v1/users/{username}/profile, POST/DELETE /api/v1/relationships/{userId}/follow, POST /api/v1/relationships/requests/{id}/decide, POST/DELETE /api/v1/safety/blocks.	pytest BOLA & graph tests verifying: (a) reciprocal ACCEPTED follow sets is_mutual = TRUE on both edges via DB trigger; (b) non-follower receives 404 on private user's relations list; (c) blocking atomically deletes follow edges in both directions.	**Git Tag:** v0.3.0-slice2. **Rollback:** alembic downgrade -1. **Rescope Gate:** Keep theme tokens to 5 static CSS variable presets (SCR-24).
Slice 3: Direct-to-B2 Media Pipeline, WebWorker	Users can select 1–10 images in SCR-15, crop/reorder/	**Included:** SCR-14, SCR-15 (with integrated SCR-16),	Slice 2 + Backblaze B2 CORS rules & Cloudflare	POST /api/v1/media/upload-intents, POST /api/v1/media	Playwright E2E + security tests verifying: (a) 3 images	**Git Tag:** v0.4.0-slice3. **Rollback:** Flip UPLOADS_E

Slice ID & Milestone	User-Visible Outcome	Included vs. Excluded Scope	Prerequisites & External Services	Domain & API Contracts Delivered	Mandatory Executable Tests & Acceptance Criteria	Rollback, Git Checkpoint & Rescope Gate
Pre-Resize & Composer State Machine (Days 11–16)	add alt-text inline, pre-compress to WebP in browser WebWorker, upload directly to B2 via presigned PUT, verify/strip EXIF via server pyvips, and inspect in Lightbox (SCR-14).	media_assets table, Cloudflare B2 Delivery Worker (cdn.swiftradish.app), 6-hour orphan cleanup job in outbox_jobs. **Excluded:** Video uploads.	Worker deployed.	/{id}/complete, GET /api/v1/media/{id}/status, DELETE /api/v1/media/{id}.	upload \rightarrow READY \rightarrow cancel 1 image; (b) EXIF GPS tags stripped; (c) SVG/polyglot & 100 MP header bomb rejected 422; (d) cdn.swiftradish.app strips query strings and returns Cache-Control: immutable.	NABLED=false. **Rescope Gate:** If B2 US-West upload RTT from India >2.5\text{s} after WebWorker compression, point S3 env vars to Cloudflare R2 free tier (10 GB free).
Slice 4: Standard Posts, Co-Plot Cards, RSVPs, Shared Carousels & Plot Thread (Days 17–22)	Users can publish posts and Co-Plots (SCR-15), view public/auth detail (SCR-02/13), RSVP (Going/Maybe) with capacity locking, contribute collaborative carousel slides, approve slides (SCR-17), and chat in	**Included:** SCR-02/13, SCR-15, SCR-17, posts, co_plots, co_plot_participants, conversations & messages (scoped to CO_PLOT_THREAD with WebSocket + REST fallback). **Excluded:** Standalone 1:1 DM inbox (Stage 2).	Slice 3 completed.	POST/GET/DELETE /api/v1/posts, POST /api/v1/plots/{id}/rsvp, POST /api/v1/plots/{id}/submissions, POST /api/v1/plots/{id}/submissions/{subId}/decide, POST /api/v1/ws/ticket, WS /ws.	Playwright E2E test: Host plants Co-Plot \rightarrow composer resets cleanly \rightarrow immediate 2nd post succeeds \rightarrow Mutual RSVPs Going & uploads slide (auto-approved) \rightarrow Non-mutual	**Git Tag:** v0.5.0-slice4. **Rollback:** Disable collaborative slide submissions via COPLOT_UPLOADS_ENABLED=false. **Rescope Gate:** If WebSocket debugging exceeds 2 days, ship SCR-13 Plot Thread using POST /messages +

Slice ID & Milestone	User-Visible Outcome	Included vs. Excluded Scope	Prerequisites & External Services	Domain & API Contracts Delivered	Mandatory Executable Tests & Acceptance Criteria	Rollback, Git Checkpoint & Rescope Gate
	the Co-Plot thread.				uploads slide \rightarrow Host approves in SCR-17 \rightarrow Plot thread deduplicates reconnect messages via client_msg_id.	5s REST cursor polling first, then layer WebSocket push.
Slice 5: Starter Patches, Dual Feeds, Hybrid Search, Activity Center & Zero-Touch Statutory Safety (v1.0.0-mvp) (Days 23–27)	Completes the 15-screen MVP Core: users join \ge 3 starter Patches (SCR-09), browse Following & Discover feeds (SCR-11/12), react/comment/bookmark, search (SCR-19/20), view notifications (SCR-31), file statutory reports with <1s CRITICAL_2H auto-quarantine (SCR-36/38/39), and	**Included:** SCR-03/21, SCR-09, SCR-11/12, SCR-19/20, SCR-31, SCR-33 (Delete/Export), SCR-36, SCR-38, SCR-39, /legal/grievance, patches, patch_members, post_reactions, comments, bookmarks, notifications, safety_reports, audit_events.	Slice 4 + 8 founder starter Patches seeded via scripts/seed_starter_patches.py (authentic founder content, zero fake user counters).	GET /api/v1/feed/following, GET /api/v1/feed/discover, GET /api/v1/search, GET/POST /api/v1/notifications, POST /api/v1/safety/reports, POST /api/v1/admin/moderation/cases/{id}/resolve, POST /api/v1/account/schedule-deletion.	Full 6-Gate Release Audit: (a) keyset pagination has 0 duplicate/skipped posts; (b) pg_trgm typo search "urbn sktching" matches "Urban Sketching"; (c) CRITICAL_2H report hides post in <1s and returns ticket_number; (d) UPDATE/DELETE on audit_events raises DB trigger error; (e) zero	**Git Tag:** v1.0.0-mvp-launch. **Rollback:** Switch Discover feed to chronological fallback; toggle INVITE_ONLY=true if report queue spikes. **Exit Gate:** Ready for 100-user closed beta.

Slice ID & Milestone	User-Visible Outcome	Included vs. Excluded Scope	Prerequisites & External Services	Domain & API Contracts Delivered	Mandatory Executable Tests & Acceptance Criteria	Rollback, Git Checkpoint & Rescope Gate
	export/delete accounts (SCR-33).				@axe-core/playwright violations.	
Stage 2 Fast-Follow (Slices 6–8, Post-Beta Validation)	Expands into standalone 1:1 & Group DM Inbox (SCR-27–30), Co-Plot .ics Calendar (SCR-18), User Patch Creation (SCR-22), Bookmark Folders (SCR-26), iOS/Android PWA Web Push (SCR-10, SCR-35), and Badges (SCR-32).	Built strictly one slice at a time **only after** v1.0.0-mvp-launch validates the \ge 20\% WAU Co-Plot conversion hypothesis in closed beta.	Live telemetry from v1.0.0-mvp-launch cohort.	Reuses the normalized conversations, messages, patches, and bookmarks tables already deployed in Slices 4–5.	Every Stage 2 slice must pass all 6 Release Gates before merging.	Feature-flagged per slice (DM_INBOX_ENABLED, WEB_PUSH_ENABLED).

K. Canonical Decision Register

This master register reconciles all contradictions between Phase 1, Phase 2, and the Phase 3 independent audit ([USER DECISION], [VERIFIED], [RECOMMENDATION]).

ID	Topic	Final Audit Outcome	Selected Canonical Option	Alternatives Considered	Evidence & Citations	Confidence	Consequences & Trade-Offs	Dependencies & Revisit Trigger	Blocking Status
DEC-01	MVP Launch Surface Area	**Change** ([RECOMMENDATION])	**15-Screen Consolidated MVP Core (Slices 0–5)** delivering unified	1. Phase 1 (40 screens) 2. Phase 2 (22 screens).	Consolidating 7 sub-drawers/tabs cuts solo-builder effort from 42 days to 27 days	**High**	Defers 1:1 DM inbox (SCR-27–30), Web Push (SCR-10), and user	Unlocks Stage 2 when closed beta hits \ge 20\% WAU Co-Plot conversion.	**User Sign-Off Required**

ID	Topic	Final Audit Outcome	Selected Canonical Option	Alternatives Considered	Evidence & Citations	Confidence	Consequences & Trade-Offs	Dependencies & Revisit Trigger	Blocking Status
			Co-Plots (RSVP + Shared Carousel + Plot Thread), 8 Starter Patches, Dual Feeds, Hybrid Search, and Zero-Touch Statutory Safety.		and prevents Grok/Composer 2.5 context degradation.		Patch creation (SCR-22) to Stage 2.		
DEC-02	Infrastructure Budget & Compute Host	**Change** ([USER DECISION] + [VERIFIED])	**True $0.00/Month Zero-Budget Architecture:** Vercel Hobby ($0) + OCI 0) [or Render/HF Free + Upstash Free Redis ($0)] + Sup 0) + B2 Free ($0).	1. Phase 1 ($49–69/mo Railway/R2/Supabase Pro) 2. Phase 2 ($24–49/mo).	Oracle Cloud Always Free (June 2026 limit: 2 OCPU / 12 GB RAM) runs FastAPI + Redis + workers 24/7 at $0/mo; Upstash provides 500k commands/mo free.	**High**	Requires outbox_jobs table so background work never burns idle Redis commands on Upstash fallback.	Upgrade Supabase to Pro ($25/mo) only when DB reaches 400 MB (~50k posts).	**Blocking Slice 0**
DEC-03	Supabase Port 6543	**Change** ([VERIFIED])	**Supabase Free Tier +**	1. Relying only on	Supabase Issues #36618	**High**	Surrenders prepared	Use Session Pooler	**Blocking Slice 0**

ID	Topic	Final Audit Outcome	Selected Canonical Option	Alternatives Considered	Evidence & Citations	Confidence	Consequences & Trade-Offs	Dependencies & Revisit Trigger	Blocking Status
	Pooler & Keep-Alive		**GitHub Actions 72h Keep-Alive Cron + SQLAlchemy NullPool & Full Statement Cache Disablement.**	statement_cache_size=0 (Phase 2) 2. Paying $25/mo on Day 1.	&#39227 prove SQLAlchemy + asyncpg crashes on port 6543 without NullPool, prepared_statement_cache_size=0, and UUID statement names. Cron prevents 7-day pause.		-statement caching (~15% parse overhead, negligible at <500 RPS) in exchange for 100% transaction pooler stability.	(port 5432) strictly for Alembic CLI migrations.	
DEC-04	Primary Media Storage & Upload Pipeline	**Accept Phase 2 + Enhance** ([USER DECISION] + [VERIFIED])	**Existing Private Backblaze B2 Bucket (10 GB free) + Cloudflare Bandwidth Alliance Worker (cdn.swiftradish.app) + Browser WebWorker Pre-Resi**	1. Replace B2 with Cloudflare R2 (Phase 1) 2. Upload raw 15 MB files without client pre-resize (Phase 2).	B2 gives 10 GB free + $0.006/GB/mo and $0 egress via Cloudflare Worker, using presigned PUT. Browser WebWorker pre-resize cuts India-to-	**High**	Keeps Cloudflare R2 (10 GB free) as a zero-code-change S3 env-var fallback if B2 US-West latency is ever an issue.	Requires 5-step B2 CORS + Cloudflare Worker setup in Slice 0/3.	**Blocking Slice 3**

ID	Topic	Final Audit Outcome	Selected Canonical Option	Alternatives Considered	Evidence & Citations	Confidence	Consequences & Trade-Offs	Dependencies & Revisit Trigger	Blocking Status
			ze + Server pyvips (Sema[span_101](start_span)[span_101](end_span)phore(2)).		US upload size from 12 MB to ~450 KB.				
DEC-05	India IT Rules 2021–2026 & DPDP 2025 Posture	**Change** ([VERIFIED])	**18+ Age Gate + Itemized DPDP Notice + CRITICAL_2H / STANDARD_36H SLA Queues + Instant Zero-Touch Quarantine (PENDING_MOD_SHIELD) on CRITICAL_2H Reports.**	1. 24h / 72h manual moderation queues requiring \ge 2 reports (Phase 1 & Phase 2).	2026 IT Rules amendments cut Rule 3(2)(b) sensitive takedowns from 24h to **2 hours** and 72h timelines to **36 hours**. A solo founder cannot meet a 2h clock manually 24/7.	**High**	Single CRITICAL_2H report from a verified user auto-shields the post in <1s; mitigated against troll abuse by a 1-click admin Restore & Penalize Reporter macro in SCR-39.	Consult Indian legal counsel before commercial scaling on DigiLocker age tokens and 22-language notices.	**Blocking Slice 5**
DEC-06	Visual System, Mascot & Stitch Workflow	**Accept Phase 2 Simplified** ([RECOMMENDATION])	**"Nocturnal Botanical Studio" (#0B0D11 dark / #F6F7F9 light) + 6**	1. 30 or 216 poses + 12 Lotties in MVP (Phase 1).	Prevents illustration production and Stitch prompt drift from blocking	**High**	Pairs every botanical brand term with an explicit functional label	Expand mascot poses only after D30 retention \ge 18\%.	Non-Blocking

ID	Topic	Final Audit Outcome	Selected Canonical Option	Alternatives Considered	Evidence & Citations	Confidence	Consequences & Trade-Offs	Dependencies & Revisit Trigger	Blocking Status
			Static Layered Pip SVGs (<8 KB) + Google Stitch MCP Strictly as Post-Decision Layout Reference.		core engineering.		(Following · My Patch, Communities · Patches).		

L. Canonical Implementation-Agent Handoff

The following authoritative specification governs all coding-agent sessions in Cursor Pro (Grok / Composer 2.5); the coding agent must treat this section as its binding contract.

12.1 Product Thesis, Truth Hierarchy, and Mandatory Pre-Coding Inspection

Swiftradish is a co-active social web application and installable PWA where interest communities (**Communities · Patches**) and friends turn multi-image posts directly into shared activities, contextual coordination threads, and multi-author photo albums (**Shared Activities & Albums · Co-Plots**). Across all engineering tasks, explicit user constraints and this **Phase 3 Canonical Implementation Handoff** supersede all prior documents; Swiftradish Phase 2 Specification Research.pdf governs where explicitly accepted above, while Swiftradish Product and Engineering Blueprint.pdf serves as historical reference only. Before creating or modifying any file, the coding agent must inspect the local workspace (git status, git remote -v, directory listing, .gitignore), verify that no secrets exist in tracked files, and output a concise **Slice 0 Execution Plan** listing the exact 3 to 5 files to be created in the first step for human confirmation.

12.2 Approved Zero-Budget Stack and Exact Configuration Contracts

The repository is structured as a three-part monorepo (frontend/, backend/, and cloudflare-worker/). The frontend/ directory houses the Next.js App Router application written in strict TypeScript with Tailwind CSS, Radix UI primitives, TanStack Query v5, Zustand, and idb-keyval for IndexedDB drafts and outbox persistence. The backend/ directory houses the Python 3.12+ and FastAPI 0.137+ modular monolith using Starlette 1.0+ lifespan context managers, SQLAlchemy 2.0 Async (asyncpg), Alembic, Pydantic v2 (extra='forbid'),

pyjwt[crypto], aioboto3, pyvips, and structlog. The cloudflare-worker/ directory contains the lightweight Cloudflare Worker script (cdn-b2-signer/index.ts) bound to cdn.swiftradish.app that strips query parameters, validates ^/media/[0-9a-f-]{36}/(thumb_400w|feed_1080w|full_2048w)\.webp$, signs AWS SigV4 GET and HEAD requests to the private Backblaze B2 bucket using a read-only key scoped to media/, and injects Cache-Control: public, max-age=31536000, immutable, Content-Security-Policy: default-src 'none', and X-Content-Type-Options: nosniff.
In backend/src/core/database.py, runtime application queries must connect to DATABASE_POOLER_URL (Supabase Transaction Pooler port 6543) using poolclass=NullPool and connect_args={"statement_cache_size": 0, "prepared_statement_cache_size": 0, "prepared_statement_name_func": lambda: f"__asyncpg_{uuid4()}__", "command_timeout": 10}, while Alembic migrations (alembic/env.py) connect to DATABASE_DIRECT_URL (Supabase Session Pooler port 5432) and all ORM relationships enforce lazy="raise". In backend/src/core/security.py, the backend must read SUPABASE_JWKS_URL (https://<project-ref>.supabase.co/auth/v1/.well-known/jwks.json) and EXPECTED_ISSUER (https://<project-ref>.supabase.co/auth/v1) strictly from server environment variables, verify bearer tokens via PyJWKClient (cached 1 hour) and jwt.decode(..., algorithms=["ES256"], audience="authenticated", issuer=settings.EXPECTED_ISSUER), and check revoked_jti:{jti} in Redis on all mutating requests (POST, PATCH, PUT, DELETE) and /api/v1/ws/ticket calls.

12.3 Canonical .env.example Template (Never Commit Real Secrets)

The coding agent must commit .env.example at the repository root containing only safe placeholder values across the following 18 required environment keys ([RECOMMENDATION], High Confidence):

Environment Variable Key	Canonical Placeholder Value	Architectural Purpose & Scope
APP_ENV	development	Execution mode (development, test, or production).
DATABASE_POOLER_URL	postgresql+asyncpg://postgres.<project-ref>:<password>@aws-0-<region>.pooler.supabase.com:6543/postgres	Runtime FastAPI transaction pooler connection (NullPool + statement cache disabled).
DATABASE_DIRECT_URL	postgresql+asyncpg://postgres.<project-ref>:<password>@aws-0-<region>.pooler.supabase.com:5432/postgres	Persistent session pooler connection used exclusively by Alembic CLI migrations.
SUPABASE_URL	https://<project-ref>.supabase.co	Base Supabase project URL for Auth handshakes.
SUPABASE_ANON_KEY	<placeholder-anon-key>	Public anon key used by client/SSR Auth helpers (never service-role).
SUPABASE_JWKS_URL	https://<project-ref>.supabase.co/auth/v1/.well-known/jwks.json	Pinned asymmetric ES256 JWKS endpoint for local FastAPI verification.
EXPECTED_ISSUER	https://<project-ref>.supabase.co/auth/v1	Pinned JWT iss trust anchor preventing SSRF and spoofing.
REDIS_URL	redis://localhost:6379/0	Local OCI Redis 7 instance or

Environment Variable Key	Canonical Placeholder Value	Architectural Purpose & Scope
		Upstash TLS endpoint (rediss://...).
EMBED_WORKER_IN_APP	true	Runs outbox_jobs dispatcher inside FastAPI process to save RAM and Redis commands.
S3_ENDPOINT_URL	https://s3.<region>.backblazeb2.com	Backblaze B2 S3-compatible endpoint (or Cloudflare R2 fallback endpoint).
S3_REGION	<region>	B2 bucket region identifier (e.g., us-west-004 or eu-central-003).
S3_BUCKET_NAME	<private-b2-bucket-name>	Name of the user's private (allPrivate) Backblaze B2 bucket.
S3_ACCESS_KEY_ID	<placeholder-b2-rw-key-id>	Scoped read/write Backblaze Application Key ID for FastAPI backend.
S3_SECRET_ACCESS_KEY	<placeholder-b2-rw-application-key>	Scoped read/write Backblaze Application Key secret (server-only).
CDN_PUBLIC_BASE_URL	https://cdn.swiftradish.app	Custom domain bound to the Cloudflare Bandwidth Alliance Delivery Worker.
TURNSTILE_SECRET_KEY	<placeholder-turnstile-secret>	Cloudflare Turnstile secret key protecting /register, /login, and /legal/grievance.
UPLOADS_ENABLED	true	Global kill-switch to pause media uploads instantly during spend/abuse anomalies.
INVITE_ONLY	false	Emergency registration gate if moderation queues approach statutory SLA capacity.

12.4 Required Operational Documentation in docs/

In Slice 0, the coding agent must generate and maintain docs/OPERATIONS_RUNBOOK.md covering six mandatory procedures. First, **Local Setup & Boot** must document running docker compose up -d (local Postgres 16, Redis 7, MinIO S3 mock), executing alembic upgrade head, and starting FastAPI (uvicorn src.main:app --reload) and Next.js (pnpm dev). Second, **Test Execution** must specify the exact terminal commands for unit tests (pytest tests/unit), real-DB integration and BOLA tests (pytest tests/integration tests/security), and Playwright E2E + axe accessibility tests (pnpm playwright test). Third, **Migration Workflow** must detail creating reversible revisions (alembic revision --autogenerate -m "..."), testing up/down reversibility against port 5432, and verifying the FastAPI startup preflight gate. Fourth, **Backblaze B2 + Cloudflare Worker Setup** must provide the exact B2 CORS JSON rule (PUT, GET, HEAD for http://localhost:3000 and production origin with AllowedHeaders: ["Content-Type", "Content-Length"], ExposeHeaders: ["ETag"]), Bucket Info {"Cache-Control": "public, max-age=31536000, immutable"}, and deployment steps for cloudflare-worker/. Fifth,

Encrypted Backup & Monthly Restore Drill must document running scripts/backup_db_to_b2.sh (pg_dump --format=custom encrypted with age uploaded to s3://<bucket>/backups/) and scripts/verify_backup_restore.sh (restoring into an ephemeral Postgres 16 container and asserting row counts + alembic current == head). Sixth, **Emergency Rollback & Incident Kill-Switches** must document toggling UPLOADS_ENABLED=false and INVITE_ONLY=true, reverting Alembic migrations (alembic downgrade -1), and executing the 72-hour DPDP Rule 7 breach notification script.

12.5 Ten Prohibited Shortcuts (Automatic Audit Rejection)

The coding agent is strictly forbidden from taking ten implementation shortcuts under penalty of automatic slice rejection. Specifically, the agent must never implement **fake success states** (showing a success toast, clearing a composer, or marking an RSVP Going before the server transaction commits and returns 200/201 or msg.ack); **inert UI controls** (rendering buttons, tabs, or menu items on an MVP screen without a working backend handler); **production mock data or fake counters** (importing mock fixture arrays inside frontend/src/ or backend/src/, or displaying fabricated user/member counts); or **Base.metadata.create_all()** (every test and runtime environment must build its schema exclusively via alembic upgrade head). Furthermore, the agent must never allow **unvalidated or proxied media uploads** (streaming image bytes through FastAPI on upload instead of presigned PUT to B2, or marking an asset READY without server HeadObject + 4 KB magic-byte + pyvips dimension and EXIF verification); **client-only authorization** (hiding a button in React or checking is_private in CSS without enforcing Plane 1 RBAC and Plane 2 Ownership, Visibility, and user_blocks in SQL); **unbounded queries or retries** (omitting keyset cursors with LIMIT <= 30, using OFFSET, or writing retry loops without max_tries = 4 and jittered exponential backoff); **unsafe private media caching** (serving staging/ or private/ prefixes through the public Cloudflare CDN Worker); **unpinned JWT decoding** (passing HS256 alongside ES256 in jwt.decode() or deriving the JWKS URL from an unverified token's iss claim); or **unexecuted test claims** (claiming a migration, linter, pytest, or playwright test passed without actually executing the command in the terminal and verifying exit code 0).

M. Final Open Questions and Next Actions

13.1 Open Questions Split by Timing Horizon

Only three true blockers require user confirmation prior to coding Slice 1, while remaining items are staged for Slice 5 or commercial scaling:

Timing Horizon	Question ID & Topic	Specific Decision or Information Needed from Builder	Impact & Default Fallback
Must Answer Before Coding Slice 1 (True Blockers)	**Q-01: Provisioned Cloud Regions** ([UNVERIFIED])	Confirm the exact regions selected on the existing **Supabase project** (e.g., ap-south-1 Mumbai vs. US/EU) and **Backblaze B2 bucket** (e.g.,	Populates .env endpoints in Slice 0.

Timing Horizon	Question ID & Topic	Specific Decision or Information Needed from Builder	Impact & Default Fallback
		us-west-004 vs. eu-central-003), and whether a custom domain is active on Cloudflare for the free Bandwidth Alliance Worker.	
Must Answer Before Coding Slice 1 (True Blockers)	**Q-02: Free Compute Host Selection** ([USER DECISION])	Choose between **Option A** (Oracle Cloud Always Free 2-OCPU / 12 GB RAM Arm VM in Hyderabad/Mumbai for 24/7 zero-sleep execution) or **Option B** (Render / Hugging Face Free Docker container + Upstash Free Serverless Redis).	Determines whether Redis runs locally in Docker (Option A) or via Upstash TLS (Option B).
Must Answer Before Coding Slice 1 (True Blockers)	**Q-03: 15-Screen MVP Core Sign-Off** ([USER DECISION])	Confirm approval of the consolidated **15-screen MVP Core (Slices 0–5)** with Co-Plot threads included in SCR-13 and the standalone 1:1 DM inbox (SCR-27–30) staged for Slice 6 post-beta.	Locks the Slice 0–5 roadmap for the Cursor coding agent.
Must Answer During Implementation (Before Slice 5 Beta)	**Q-04: Grievance Officer Disclosure** ([UNVERIFIED])	Provide the name, designation, dedicated email address, and physical contact address to populate /legal/grievance under India's IT Rules 2021 Rule 3(2).	Required before public beta users access SCR-36/SCR-38.
Can Wait Until Traction / Scale (>1,000 MAU)	**Q-05: Indian Legal Counsel Review** ([RECOMMENDATION])	Formal legal review of DigiLocker age-token verification (DPDP Section 9), Eighth Schedule language translations (DPDP Section 5/6), and SSMI threshold tracking.	Required prior to commercial monetization or scaling past closed beta.

13.2 Immediate Next Actions in Execution Order

Execution proceeds across five sequential steps ([RECOMMENDATION], High Confidence). First, the builder confirms **Q-01 through Q-03** above (Supabase/B2 regions, Option A vs. Option B free compute host, and approval of the 15-screen MVP Core). Second, the builder instructs the Cursor coding agent to execute **Slice 0 Repo & Cloud Preflight**: inspecting the fresh local repository, creating .gitignore, .env.example, DESIGN.md, AGENTS.md, and .github/workflows/supabase-keep-alive.yml, linking the local repository to https://github.com/<owner>/Swiftradish.git, and pushing the clean baseline. Third, the builder sets the Backblaze B2 bucket to allPrivate, applies the S3 CORS rules, generates the scoped read/write and read-only Application Keys, and verifies GET /api/v1/health against Supabase port 6543 (NullPool + disabled statement caches). Fourth, the builder runs **Batch 0 in Google Stitch** to generate and visually lock only the three anchor layouts—SCR-11 (Dual Home Feed), SCR-13 (Co-Plot Detail & Thread), and SCR-15 (Unified Composer)—using DESIGN.md before coding UI components. Fifth, the builder executes **Slices 1 through 5 sequentially** on dedicated feature branches (feat/slice-01-auth through feat/slice-05-safety), requiring terminal proof of all 6 Release Gates before tagging v1.0.0-mvp-launch.

N. Required Phase 3 Self-Check

Self-Check Audit Question	Audit Verification & Evidence Summary
1. Were consequential claims verified against current primary sources?	**Yes.** Verified against October 2026 primary sources for Supabase pricing/pausing, SQLAlchemy + asyncpg port 6543 bugs, Backblaze B2 / Cloudflare R2 limits and presigned PUT rules, Oracle Cloud's June 2026 Arm free-tier cut (2 OCPU / 12 GB RAM), Render's April 2026 bandwidth cut (5 GB/mo), Upstash Redis (500k cmds/mo), and India's DPDP Rules 2025 & IT Amendment Rules 2026.
2. Did the report challenge earlier reports instead of merely summarizing them?	**Yes.** Challenged and corrected Phase 1 and Phase 2 on paid hosting costs (24–69/mo vs. $0.00/mo), exposed the fatal DuplicatePreparedStatementError in Phase 2's port 6543 setup, corrected the outdated 24h/72h IT Rules takedown clocks to the 2026 2h/36h statutory timelines, and cut the 22-screen Phase 2 scope down to 15 consolidated screens.
3. Is the MVP differentiated and feasible for a solo builder?	**Yes.** Preserves 100% of the differentiated Co-Plot loop (visual invite + 1-tap RSVP + Plot Thread + multi-author Shared Memory Carousel) while cutting 37 days of secondary screen boilerplate so a solo builder using Grok and Composer 2.5 can ship reliably.
4. Are legal claims properly qualified and	**Yes.** Explicitly separates binding statutory rules

Self-Check Audit Question	Audit Verification & Evidence Summary
sourced?	(IT Rules Rule 3, DPDP Rule 7) from conservative product design choices (18+ age gate, Rule 4(8)-style dispute notice), updates takedowns to the 2026 2-hour/36-hour clocks, and provides a 5-point checklist for qualified Indian legal counsel.
5. Are current service limits/prices and cost scenarios transparent?	**Yes.** Recalculated from official 2026 pricing with explicit mathematical formulas, proving a $0.00/month run-rate at 1,000 MAU and detailing four automated abuse circuit breakers.
6. Are screens and key actions backed by real contracts and complete failure states?	**Yes.** Every retained screen in Section D and journey in Section E defines its exact API endpoints, database tables, loading/empty/error/offline/retry/rate-limit states, and post-action reset guarantees.
7. Are server-side authorization, privacy, deletion, and moderation addressed?	**Yes.** Enforces Two-Plane RBAC + BOLA in SQL (404 masking), EXIF GPS stripping, instant <1s CRITICAL_2H quarantine (PENDING_MOD_SHIELD), and 14-day account hard purge with a 180-day statutory legal hold override.
8. Are realtime guarantees described honestly?	**Yes.** Explicitly specifies durable PostgreSQL commit before msg.ack, at-least-once delivery with client_msg_id idempotent deduplication, UUIDv7 causal ordering, sync.resume gap fill, and REST polling fallback—avoiding false claims of network-level "exactly-once" delivery or iOS silent background push.
9. Are acceptance criteria measurable?	**Yes.** All SLOs in Section H and slice gates in Section J use concrete numeric thresholds (LCP <= 1.8s, <= 3 SQL queries, 0 axe violations, <1s quarantine).
10. Are unknowns and user decisions clearly separated?	**Yes.** Every consequential claim carries [VERIFIED], [INFERENCE], [RECOMMENDATION], [UNVERIFIED], or [USER DECISION] labels, and Section M isolates the 3 pre-coding user decisions.
11. Did the report avoid application code and unsupported implementation claims?	**Yes.** Zero application source code was written and zero false claims of completed implementation were made.

Works cited

1. State of Free Hosting 2026: Every Free Tier and Its Catch, https://snapdeploy.dev/state-of-free-hosting 2. Supabase Pricing: 2026 Guide to Plans, Limits, and Real-World Costs, https://www.jetadmin.io/blog/supabase-pricing-2026-guide-to-plans-limits-and-real-world-costs/

3. Best Render Alternatives in 2026 (+ Free Tier Changes), https://www.codecapsules.io/blog/best-render-alternatives-in-2026-where-to-go-when-render-falls-short/ 4. The asyncpg + PgBouncer Prepared Statement Trap - Gold Lapel, https://goldlapel.com/grounds/connection-pooling/asyncpg-pgbouncer-prepared-statement-trap 5. Python asyncpg fails with burst requests on both Supabase poolers, https://github.com/supabase/supabase/issues/39227 6. I'm getting a DuplicatePreparedStatementError when using, https://stackoverflow.com/questions/79648632/im-getting-a-duplicatepreparedstatementerror-when-using-sqlalchemy-with-asyncpg 7. INFORMATION TECHNOLOGY (INTERMEDIARY GUIDELINES, https://www.gnslegal.in/information-technology-intermediary-guidelines-and-digital-media-ethics-code-amendment-rules-2026-a-detailed-legal-analysis/ 8. AI Content Labelling Rules 2026: New IT Norms on Deepfakes and, https://vajiramandravi.com/current-affairs/ai-content-labelling-rules-2026-new-it-norms-on-deepfakes-and-takedown-timelines/ 9. Pricing : r/backblaze - Reddit, https://www.reddit.com/r/backblaze/comments/1s9kcjc/pricing/ 10. Why you should not use Vercel for RealTime apps! A ... - Medium, https://basatmaqsood.medium.com/why-you-should-not-use-vercel-for-realtime-apps-a-comprehensive-guide-to-deploy-realtime-apps-759769c590f3 11. PreparedStatementError using asyncpg and sqlalchemy #36618, https://github.com/orgs/supabase/discussions/36618 12. Supabase pricing: plans, free tier, and hidden costs - CloudZero, https://www.cloudzero.com/blog/supabase-pricing/ 13. How to Keep Supabase Free Tier Projects Active - Medium, https://shadhujan.medium.com/how-to-keep-supabase-free-tier-projects-active-d60fd4a17263 14. Upstash Pricing 2026: Redis Free Tier and Pay-as-You-Go, https://aibizhub.io/articles/upstash-pricing-2026/ 15. Oracle Cloud free tier 2026: 4 OCPU/24GB cut to 2 OCPU/12GB, https://terminalbytes.com/oracle-cloud-free-tier-changes-2026/ 16. Disabling Prepared statements - Troubleshooting - Supabase, https://supabase.com/docs/guides/troubleshooting/disabling-prepared-statements-qL8lEL 17. Connect to your database | Supabase Docs, https://supabase.com/docs/guides/database/connecting-to-postgres 18. Pricing & Fees - Supabase, https://supabase.com/pricing 19. Oracle Quietly Halves Free Tier Ampere A1 Compute Limits, https://daily.dev/posts/oracle-quietly-halves-free-tier-ampere-a1-compute-limits-with-no-public-announcement-ldgjrd9vs 20. Always Free Resources - Oracle Help Center, https://docs.oracle.com/iaas/Content/FreeTier/freetier_topic-Always_Free_Resources.htm 21. Oracle Cloud Free Tier Always Free Compute Official 2026 - Facebook, https://www.facebook.com/fb-answers/oracle-cloud-free-tier-always-free-compute-official-2026/ 22. total novice Backblaze b2 CORS questions - Reddit, https://www.reddit.com/r/backblaze/comments/13ynv06/total_novice_backblaze_b2_cors_questions/ 23. Configure CORS · Cloudflare R2 docs, https://developers.cloudflare.com/r2/buckets/cors/